

AWS en pratique

Filtrage, accès privés et dépannage réseau

Filtrage et accès privés. Méthode de dépannage réseau.

Security groups

filtrage à états

Network ACL

filtrage sans état

Endpoints

joindre AWS sans Internet

Flow Logs

voir le trafic

Dépannage

méthode et outils

Support de formation, version 1.2, octobre 2026. Parcours « AWS en pratique ». Fait suite au support « VPC et routage ».

Filtrage et accès privés

- Expliquer ce qu'est un security group et ce que signifie « à états ».
- Expliquer ce qu'est une network ACL et ce que signifie « sans état ».
- Choisir entre les deux, et savoir les combiner.
- Chaîner des security groups : load balancer, application, base.
- Distinguer endpoint passerelle et endpoint d'interface, et dire quand les utiliser.
- Activer les VPC Flow Logs et lire un enregistrement.

Prérequis. Les chapitres « VPC et sous-réseaux » et « Routage et accès à Internet » : VPC, sous-réseaux public, privé et isolé, tables de routage, Internet Gateway, NAT Gateway, adresses publiques.

Méthode de dépannage réseau

- Interpréter un symptôme : délai dépassé, connexion refusée, nom non résolu.
- Appliquer une méthode en cinq points : route, security group, network ACL, adresse publique, DNS.
- Utiliser Reachability Analyzer pour trouver le composant qui bloque.
- Utiliser les Flow Logs pour voir ce qui se passe réellement.
- Résoudre les pannes les plus courantes d'un VPC.

Fil rouge. Le VPC de UtopiosShop construit précédemment : il a des routes, mais aucun filtrage. Ces deux chapitres le sécurisent, puis apprennent à le dépanner.

Filtrage et accès privés	
Security groups	Règles, états, sources, security group par défaut.
Network ACL	Règles numérotées, ports éphémères, comparaison.
Chaînage	Un security group comme source d'un autre.
VPC endpoints	Passerelle, interface, politique, DNS privé.
VPC Flow Logs	Activation, format, lecture, requêtes.

Méthode de dépannage réseau	
Méthode	Symptômes, cinq points de contrôle, commandes de test.
Outils	Reachability Analyzer, Flow Logs, carte des ressources.
Cas pratiques	Six pannes courantes, du symptôme à la correction.

Convention des schémas. Aux couleurs déjà utilisées (vert public, turquoise privé, gris-bleu isolé, violet VPC) s'ajoute le cadre rouge en pointillés, qui représente un security group autour des ressources qu'il protège.

Navigation. Flèches gauche et droite ou barre d'espace, **M** pour le sommaire, **F** pour le plein écran.

Filtrage et accès privés, partie 1

Les security groups

Le pare-feu de chaque ressource : il dit qui a le droit de lui parler, et sur quel port.

- Deux niveaux de filtrage
- Définition et propriétés
- Anatomie d'une règle
- Le filtrage à états
- Le security group par défaut
- Création et bonnes pratiques

Où l'on en est : des routes, pas encore de filtrage

Le routage a créé des chemins. Par la route locale, toute ressource du VPC peut en joindre une autre ; par l'Internet Gateway, les sous-réseaux publics sont reliés à Internet. Reste à décider qui a le droit d'emprunter ces chemins.

Ce que le filtrage apporte

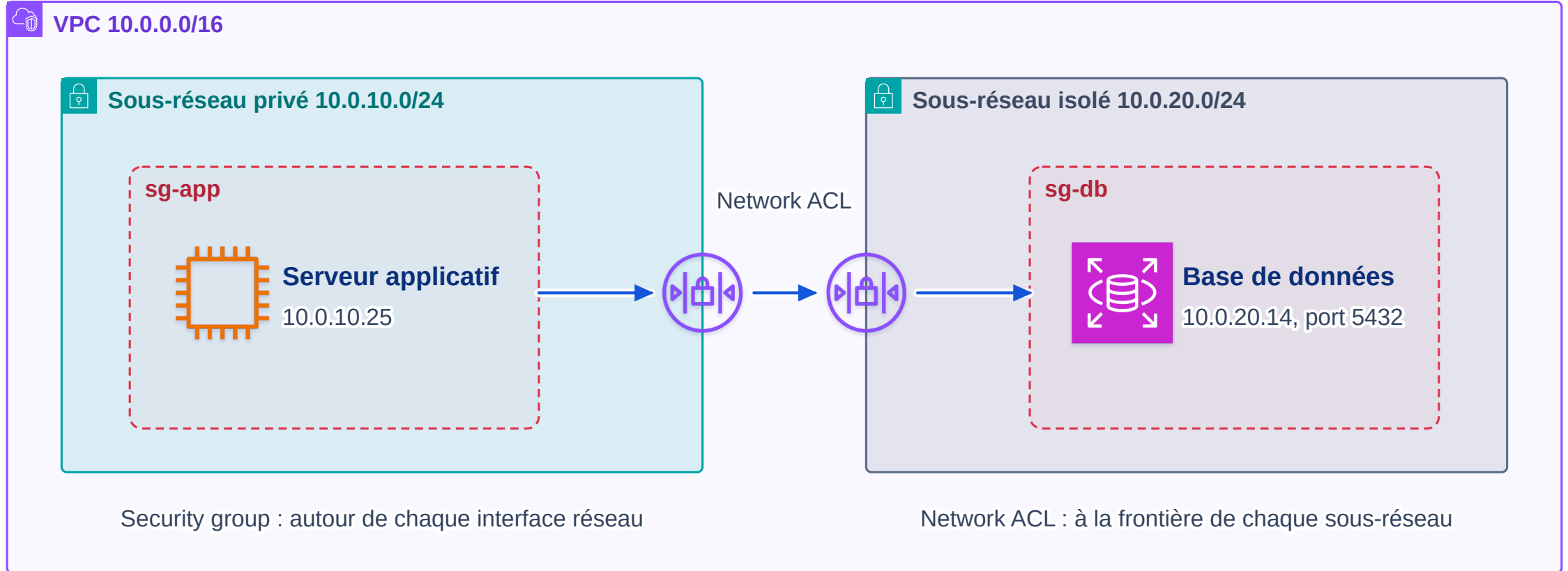
- **Limiter l'exposition** : seul le port utile est ouvert, et seulement à qui en a besoin.
- **Cloisonner** : la compromission d'un serveur ne donne pas accès à tous les autres.
- **Appliquer le moindre privilège au réseau**, comme IAM l'applique aux API.

	Security group	Network ACL
S'applique à	Une interface réseau.	Un sous-réseau.
Rôle	Le filtrage principal, au plus près de la ressource.	Un garde-fou supplémentaire, facultatif.
Dans la pratique	Toujours utilisé.	Souvent laissée ouverte.

Router n'est pas autoriser. Le routage dit s'il existe un chemin ; le filtrage dit si ce trafic a le droit de passer. Un paquet n'arrive que si les deux sont d'accord.

Deux plans à ne pas confondre. IAM contrôle qui peut *appeler l'API* d'AWS (créer une instance). Les security groups contrôlent qui peut se *connecter* à la ressource (ouvrir une session, envoyer une requête).

Schéma : deux niveaux de filtrage



Lecture. Pour aller du serveur applicatif à la base, une connexion sort du security group de l'un, franchit la network ACL de chaque sous-réseau, puis entre dans le security group de l'autre. Chaque couche peut refuser.

Dans un même sous-réseau. Deux ressources du même sous-réseau ne passent pas par la network ACL : seuls leurs security groups filtrent. C'est une raison de plus pour en faire le filtrage principal.

Qu'est-ce qu'un security group

Définition : security group

Ensemble de règles d'autorisation attaché à une ou plusieurs interfaces réseau, qui filtre le trafic entrant et sortant de chacune. Il se comporte comme un pare-feu virtuel propre à la ressource.

Propriété	Conséquence
Attaché à une interface	Il suit la ressource, quel que soit son sous-réseau.
Autorisations seulement	Une règle ne peut qu'autoriser. Il n'existe pas de règle de refus.
Refus par défaut	Ce qu'aucune règle n'autorise est rejeté.
À états	La réponse à une connexion autorisée passe automatiquement.
Sans ordre	Toutes les règles sont examinées : si l'une autorise, le trafic passe.
Effet immédiat	Une modification s'applique aussitôt à toutes les ressources membres.
Propre à un VPC	Un security group appartient à un VPC et ne sert que dans celui-ci.
Gratuit	Aucun coût : en créer autant que nécessaire.

À sa création

- **Aucune règle entrante** : rien ne peut entrer.
- **Une règle sortante** qui autorise tout, vers toutes les destinations.

Une ressource protégée par un security group neuf peut donc sortir, mais personne ne peut la joindre.

Ce que l'on retrouve d'IAM. Refus par défaut, et union des autorisations. Mais ici, aucun refus explicite : pour interdire une adresse précise, il faut une network ACL.

Champ	Contenu	Exemple
Sens	Entrant (inbound) ou sortant (outbound).	Entrant
Protocole	TCP, UDP, ICMP, ou tous.	TCP
Plage de ports	Un port ou un intervalle. Concerne le port de destination .	443
Source ou destination	Qui est autorisé : une plage CIDR, un autre security group, ou une liste de préfixes.	0.0.0.0/0
Description	Texte libre : à quoi sert la règle.	HTTPS depuis Internet

Règles entrantes de sg-alb			
TCP	443	0.0.0.0/0	HTTPS depuis Internet
TCP	80	0.0.0.0/0	HTTP, redirigé vers HTTPS

Lecture

« Autoriser, en entrée, les connexions TCP vers le port 443, d'où qu'elles viennent. » Tout le reste est refusé : le port 22, le port 5432, le ping.

Chaque règle se lit comme une phrase : **qui** (la source) peut joindre **quoi** (le port).

Définition : trafic entrant (ingress)

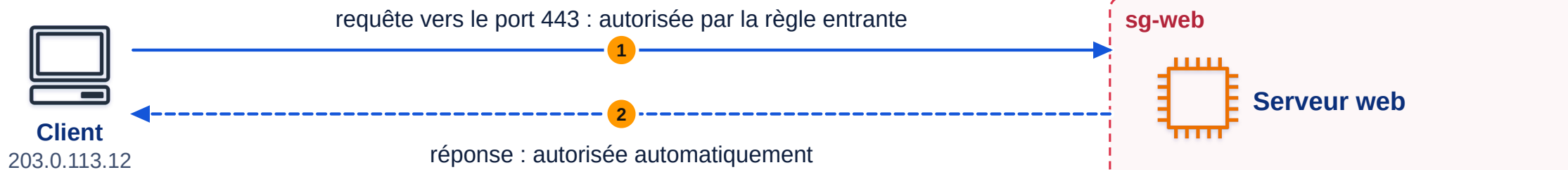
Connexions ouvertes par un tiers vers la ressource. Une règle entrante en désigne la source.

Définition : trafic sortant (egress)

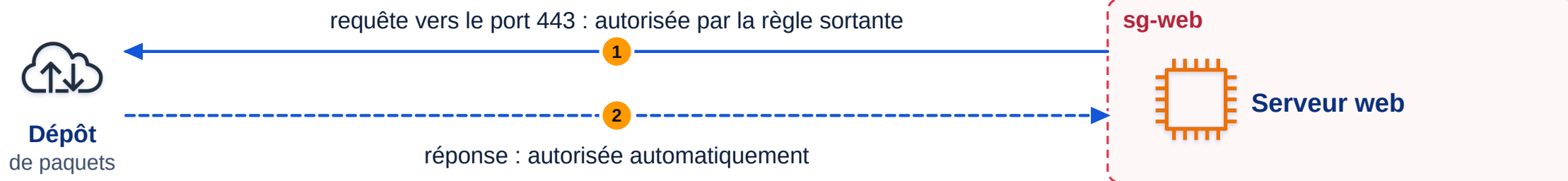
Connexions ouvertes par la ressource vers un tiers. Une règle sortante en désigne la destination.

Schéma : le filtrage à états

Connexion entrante : une règle entrante suffit



Connexion sortante : une règle sortante suffit



Définition : filtrage à états (stateful)

Filtrage qui mémorise les connexions autorisées et laisse passer leurs réponses sans consulter les règles du sens opposé.

Conséquence. On n'écrit que la règle du sens dans lequel la connexion est **ouverte**. Un serveur web n'a besoin d'aucune règle sortante pour répondre à ses clients, et une instance qui télécharge une mise à jour n'a besoin d'aucune règle entrante.

Security groups

Les sources et destinations possibles

Type	Exemple	Usage
Plage IPv4	0.0.0.0/0	Tout Internet : pour un service public (load balancer).
Plage IPv4	203.0.113.0/24	Le réseau d'un bureau, d'un partenaire.
Adresse unique	198.51.100.14/32	Un poste précis. La console propose « My IP ».
Plage du VPC	10.0.0.0/16	Tout ce qui se trouve dans le VPC.
Security group	sg-0a1b2c3d (sg-alb)	Toutes les ressources membres de ce security group, quelles que soient leurs adresses.
Liste de préfixes	pl-23ad484a	Un ensemble nommé de plages : les adresses de S3, de CloudFront, ou une liste que vous gérez.

Définition : liste de préfixes (prefix list)

Ensemble nommé de plages CIDR, géré à un seul endroit et utilisable comme source ou destination dans plusieurs règles.

La source la plus utile. Désigner un autre security group plutôt qu'une plage d'adresses : la règle reste juste quand les instances changent, se multiplient ou changent d'adresse. C'est le principe du chaînage, étudié plus loin.

La source à surveiller. 0.0.0.0/0 en entrée n'a sa place que sur les ports d'un service réellement public, 80 et 443. Sur le port 22, 3389 ou celui d'une base de données, c'est une exposition directe aux robots qui balaient Internet en permanence.

Relations

- Une interface réseau peut porter **plusieurs** security groups : leurs règles s'additionnent.
- Un security group peut protéger **plusieurs** ressources : toutes reçoivent les mêmes règles.
- Être dans le même security group ne donne aucun droit de se parler : il faut une règle qui l'autorise.

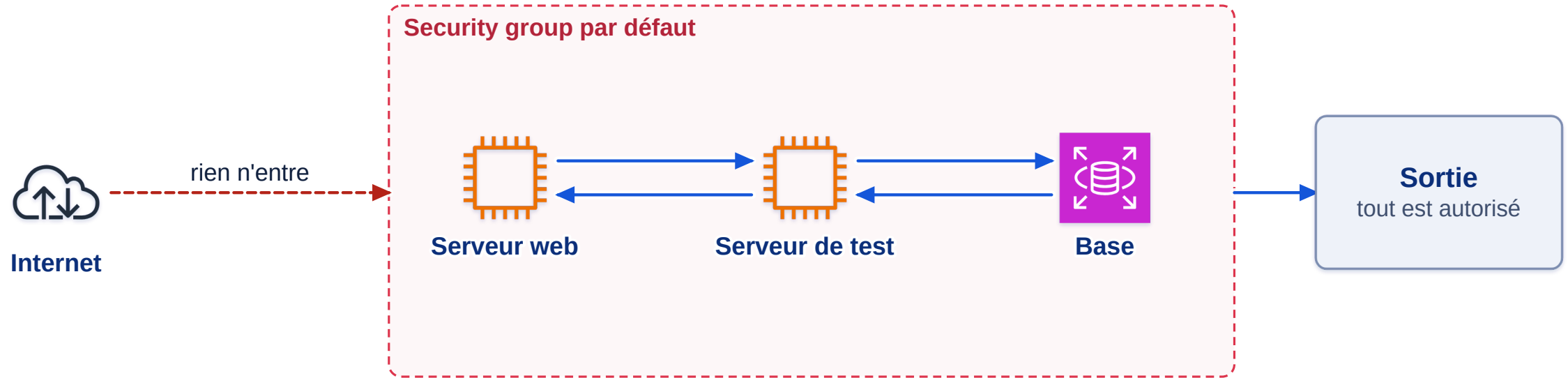
Organisation recommandée

- Un security group **par rôle** : `sg-alb`, `sg-app`, `sg-db`. Pas un par instance, pas un pour tout.
- Un nom et une description qui disent le rôle.
- Une description sur chaque règle : dans six mois, personne ne saura pourquoi le port 8443 est ouvert.
- Éventuellement un security group transversal, ajouté à toutes les instances : supervision, administration.

Quota par défaut	Valeur
Security groups par interface réseau	5
Règles entrantes par security group	60
Règles sortantes par security group	60
Security groups par région	2 500

Qui possède un security group. Les instances, mais aussi les load balancers, les bases RDS, les fonctions Lambda reliées au VPC, les endpoints d'interface, les tâches ECS : tout ce qui a une interface réseau.

Schéma : le security group par défaut



Tous les membres se parlent sans restriction, sur tous les ports.

Le serveur de test atteint la base : ce n'est sans doute pas voulu.

Définition : security group par défaut

Security group créé avec chaque VPC, qui autorise tout le trafic entre ses propres membres et toute sortie. Il ne peut pas être supprimé.

Pourquoi l'éviter. Toute ressource créée sans préciser de security group le reçoit. On y retrouve donc des ressources sans rapport, qui se parlent librement. Bonne pratique : ne jamais l'utiliser, et lui retirer toutes ses règles.

Port	Service	Ouverture habituelle
80	HTTP	Internet, sur le load balancer.
443	HTTPS	Internet, sur le load balancer.
22	SSH	Jamais à Internet ; une adresse précise, ou rien avec Session Manager.
3389	RDP (Windows)	Même règle que SSH.
3306	MySQL, MariaDB	Le security group de l'application.
5432	PostgreSQL	Le security group de l'application.
6379	Redis, Valkey	Le security group de l'application.
8080, 8443	Applications web	Le security group du load balancer.
53	DNS (UDP et TCP)	En sortie, vers le résolveur.

Définition : ICMP

Protocole de messages de contrôle du réseau, distinct de TCP et d'UDP. Le ping et certains messages d'erreur l'utilisent ; il n'a pas de numéro de port.

ICMP et ping

- Le ping utilise ICMP, pas TCP : il lui faut sa propre règle.
- Un security group sans règle ICMP ne répond pas au ping, même si le port 443 fonctionne.
- « Le ping ne passe pas » ne prouve donc rien sur l'état d'un service.

Tester un port, pas la machine. Pour vérifier qu'un service est joignable, on teste son port : `nc -zv 10.0.20.14 5432` ou `curl -v https://...`. C'est ce que le security group filtre.

Ports d'administration. SSH et RDP ouverts à `0.0.0.0/0` figurent en tête de tous les rapports d'audit. Session Manager permet de s'en passer complètement.

Console : les règles d'un security group

aws EC2 > Security Groups > Create security group

Security group name

user7-sg-alb

Description

Load balancer public de UtopiosShop

VPC

user7-vpc (vpc-0a1b...) ▼

Create security group

aws Security Groups > user7-sg-alb > Edit inbound rules

Type

HTTPS ▼

Protocol / Port range

TCP / 443

Source

Anywhere-IPv4 : 0.0.0.0/0 ▼

Description

HTTPS depuis Internet

Save rules

Onglet	Contenu
Inbound rules	Ce qui peut entrer.
Outbound rules	Ce qui peut sortir.
Tags	Nom et étiquettes.

À savoir

- Le nom et la description d'un security group ne se modifient plus après création : les choisir avec soin.
- Chaque règle possède son propre identifiant (sgr - ...) et peut porter des étiquettes.
- La page d'une instance, onglet **Security**, affiche l'ensemble des règles qui s'appliquent à elle, tous security groups confondus.

Où se trouvent-ils. Les security groups apparaissent dans la console EC2 et dans la console VPC : c'est la même liste.

Les security groups des services managés

Ressource	Règle entrante habituelle	Remarque
Load balancer public	80 et 443 depuis 0.0.0.0/0.	Seule ressource ouverte à Internet.
Instances, tâches ECS	Port de l'application depuis le security group du load balancer.	Même security group pour toutes les instances du même rôle.
Base RDS, Aurora	Port du moteur depuis le security group de l'application.	Le security group se choisit à la création de la base.
ElastiCache	6379 depuis le security group de l'application.	Même principe que la base.
Fonction Lambda reliée au VPC	Aucune : une fonction ne reçoit pas de connexion.	Elle porte un security group pour que les ressources qu'elle appelle puissent l'autoriser.
Endpoint d'interface	443 depuis les ressources clientes.	Oubli fréquent : l'endpoint existe, mais refuse les connexions.
Nœuds et pods EKS	Règles créées et gérées par le service.	Ne pas les modifier à la main.

Principe commun. Tout ce qui possède une interface réseau dans le VPC porte un security group, y compris les services qu'AWS exploite pour vous. Leur filtrage s'écrit de la même façon que celui d'une instance.

NAT Gateway et endpoint passerelle font exception : ils n'ont pas de security group. On ne les filtre que par le routage et, au besoin, par une network ACL.

Ligne de commande : créer un security group

\$ Prérequis : AWS CLI connectée, variable VPC_ID définie ; remplacer user7 par votre nom d'utilisateur

1. Créer le security group du load balancer

```
SG_ALB=$(aws ec2 create-security-group --group-name user7-sg-alb \
--description "Load balancer public de UtopiosShop" --vpc-id $VPC_ID \
--tag-specifications 'ResourceType=security-group,Tags=[{Key=Name,Value=user7-sg-alb},{Key=Owner,Value=user7}]' \
--query GroupId --output text)
```

2. Autoriser HTTPS depuis Internet, avec une description

```
aws ec2 authorize-security-group-ingress --group-id $SG_ALB \
--ip-permissions 'IpProtocol=tcp,FromPort=443,ToPort=443,IpRanges=[{CidrIp=0.0.0.0/0,Description="HTTPS depuis Internet"}]'
```

3. Lire les règles : sens, protocole, ports, source

```
aws ec2 describe-security-group-rules --filters Name=group-id,Values=$SG_ALB --output table \
--query 'SecurityGroupRules[].[IsEgress,IpProtocol,FromPort,ToPort,CidrIpv4,ReferencedGroupInfo.GroupId,Description]'
```

4. Retirer une règle

```
aws ec2 revoke-security-group-ingress --group-id $SG_ALB --protocol tcp --port 443 --cidr 0.0.0.0/0
```

5. Audit : quels security groups du VPC ouvrent le port 22 à tout Internet ?

```
aws ec2 describe-security-groups --output table \
--filters Name=vpc-id,Values=$VPC_ID Name=ip-permission.from-port,Values=22 Name=ip-permission.cidr,Values=0.0.0.0/0 \
--query 'SecurityGroups[].[GroupId,GroupName]'
```

Vocabulaire de l'API. ingress désigne le trafic entrant, egress le trafic sortant. authorize ajoute une règle, revoke la retire.

Bonnes pratiques

- Un security group par rôle applicatif.
- En entrée, le seul port nécessaire, depuis la seule source nécessaire.
- Des security groups comme sources, plutôt que des plages d'adresses.
- 0.0.0.0/0 uniquement sur les ports 80 et 443 d'un service public.
- Aucun port d'administration ouvert : Session Manager.
- Une description sur chaque règle.
- Security group par défaut vidé de ses règles et inutilisé.
- Revue périodique : règles inutilisées, sources trop larges.

Erreur	Conséquence
Port 22 ou 3389 ouvert à 0.0.0.0/0	Tentatives d'intrusion en continu.
« All traffic » depuis 0.0.0.0/0 « pour tester »	La règle provisoire reste en place.
Port de base de données ouvert à Internet	Données exposées.
Un seul security group pour toutes les ressources	Aucun cloisonnement entre niveaux.
Adresse d'instance écrite en source	Règle fausse dès que l'instance est remplacée.
Règle sur le mauvais security group	Sans effet : la ressource visée n'en est pas membre.
Confondre port source et port de destination	La règle ne correspond à aucune connexion.
Croire qu'un security group peut refuser	Recherche vaine d'une règle « deny ».

Filtrage et accès privés, partie 2

Les network ACL

Le filtre du sous-réseau : plus rustique que le security group, et capable d'une chose que celui-ci ne sait pas faire : refuser.

- Définition et propriétés
- Le filtrage sans état
- Les ports éphémères
- Règles numérotées et ordre d'évaluation
- Security group ou network ACL
- Quand utiliser une network ACL

Qu'est-ce qu'une network ACL

Définition : network ACL (liste de contrôle d'accès réseau)

Liste ordonnée de règles d'autorisation et de refus, associée à un ou plusieurs sous-réseaux, qui filtre le trafic à l'entrée et à la sortie de chacun.

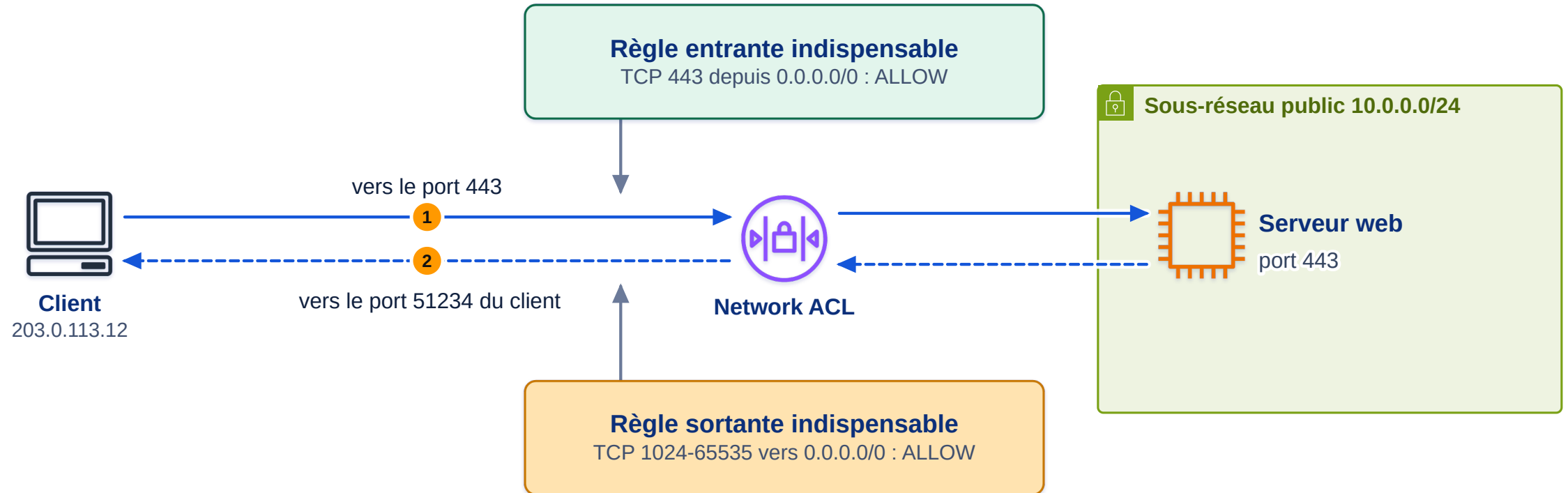
Propriété	Conséquence
Associée à un sous-réseau	Elle filtre tout ce qui franchit sa frontière, pour toutes les ressources qu'il contient.
Autorise et refuse	Une règle vaut ALLOW ou DENY.
Sans état	La réponse à une connexion n'est pas autorisée d'office : il faut une règle dans chaque sens.
Règles numérotées	Lues par numéro croissant ; la première qui correspond décide.
Refus final	Une dernière règle, notée  , refuse tout ce qui n'a pas été traité.
Une par sous-réseau	Un sous-réseau est associé à une seule network ACL ; une network ACL peut servir plusieurs sous-réseaux.

	Network ACL par défaut	Network ACL personnalisée
Origine	Créée avec le VPC.	Créée par vous.
Règles initiales	Tout autoriser, dans les deux sens.	Tout refuser, dans les deux sens.
Sous-réseaux	Tous ceux sans association explicite.	Ceux que vous lui associez.

État de départ. Dans un VPC que l'on vient de créer, la network ACL par défaut laisse tout passer : elle est transparente, et c'est le security group qui fait tout le travail. Beaucoup d'architectures en restent là.

Piège. Associer à un sous-réseau une network ACL personnalisée toute neuve coupe aussitôt tout son trafic : elle ne contient que la règle de refus.

Schéma : le filtrage sans état



Définition : filtrage sans état (stateless)

Filtrage qui examine chaque paquet isolément, sans mémoire des connexions : l'aller et le retour sont deux trafics indépendants, soumis chacun à ses règles.

L'oubli classique. On autorise le port 443 en entrée, on oublie les ports éphémères en sortie : la requête arrive au serveur, la réponse est bloquée au retour. Vu du client, la connexion expire, exactement comme si rien n'était ouvert.

Les ports éphémères

Définition : port éphémère

Port source choisi au hasard par le système du client pour la durée d'une connexion. C'est vers ce port que le serveur renvoie sa réponse.

Ce qui se passe dans une connexion

- Le client ouvre une connexion **depuis** un port éphémère, par exemple 51234, **vers** le port 443 du serveur.
- Le serveur répond **depuis** son port 443 **vers** le port 51234 du client.
- À la connexion suivante, le client prend un autre port.

On ne peut donc pas prévoir le port de retour : il faut autoriser toute la plage.

Origine de la connexion	Plage de ports éphémères
Linux récent	32768 à 60999
Windows	49152 à 65535
Load balancer, NAT Gateway, Lambda	1024 à 65535

En pratique. On autorise **1024 à 65535** pour le trafic de retour : la plage couvre tous les cas.

Avec un security group, cette question ne se pose jamais : le suivi des connexions s'en charge. C'est la principale raison pour laquelle les network ACL sont plus délicates à écrire.

Dans les deux sens. Un sous-réseau qui reçoit des connexions et en ouvre a besoin des ports éphémères en sortie (pour répondre) et en entrée (pour recevoir les réponses).

Network ACL

Anatomie des règles d'une network ACL

Règles entrantes : sous-réseau public				
100	TCP	443	0.0.0.0/0	ALLOW
110	TCP	80	0.0.0.0/0	ALLOW
120	TCP	1024-65535	0.0.0.0/0	ALLOW
*	Tous	Tous	0.0.0.0/0	DENY

Règles sortantes : sous-réseau public				
100	TCP	8080	10.0.10.0/23	ALLOW
110	TCP	443	0.0.0.0/0	ALLOW
120	TCP	1024-65535	0.0.0.0/0	ALLOW
*	Tous	Tous	0.0.0.0/0	DENY

Colonnes : numéro, protocole, ports, source ou destination, action.

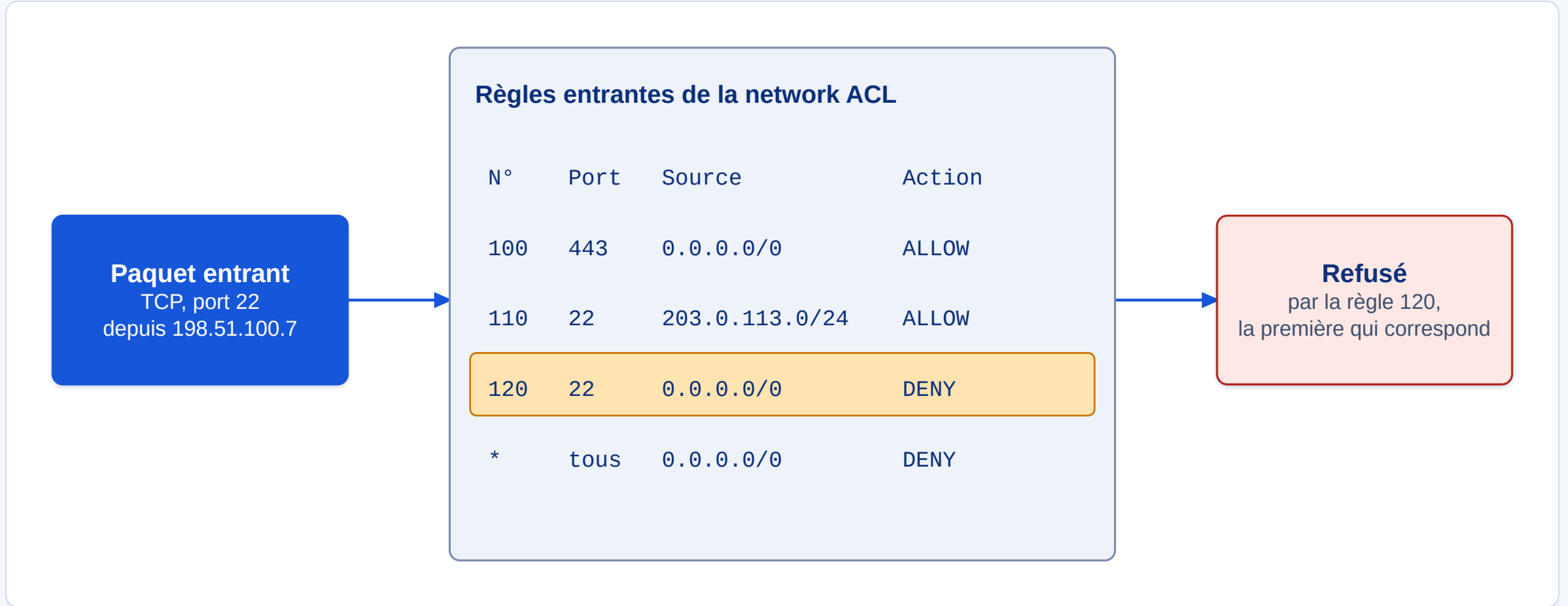
Règle	Rôle
Entrante 100, 110	Les clients joignent le load balancer.
Entrante 120	Retour des connexions ouvertes par le load balancer et la NAT Gateway.
Sortante 100	Le load balancer joint les serveurs applicatifs des sous-réseaux privés.
Sortante 110	La NAT Gateway sort vers Internet.
Sortante 120	Réponses renvoyées aux clients.

Conventions d'écriture

- Numéroter de 100 en 100, ou de 10 en 10 : on garde la place d'insérer une règle.
- Les refus ciblés portent de petits numéros, pour passer avant les autorisations.
- Une source ne peut être qu'une plage CIDR : pas de référence à un security group.

Quota : 20 règles par sens, extensible à 40.

Schéma : l'évaluation dans l'ordre



Lecture. Le paquet vient d'une adresse extérieure à 203.0.113.0/24 : la règle 110 ne correspond pas. La règle 120 correspond et refuse. La règle * n'est jamais atteinte.

L'ordre décide. Si le refus était numéroté 105, il passerait avant l'autorisation 110 et bloquerait aussi le bureau. À l'inverse d'un security group, où l'ordre n'existe pas, une network ACL se lit de haut en bas.

Security group ou network ACL

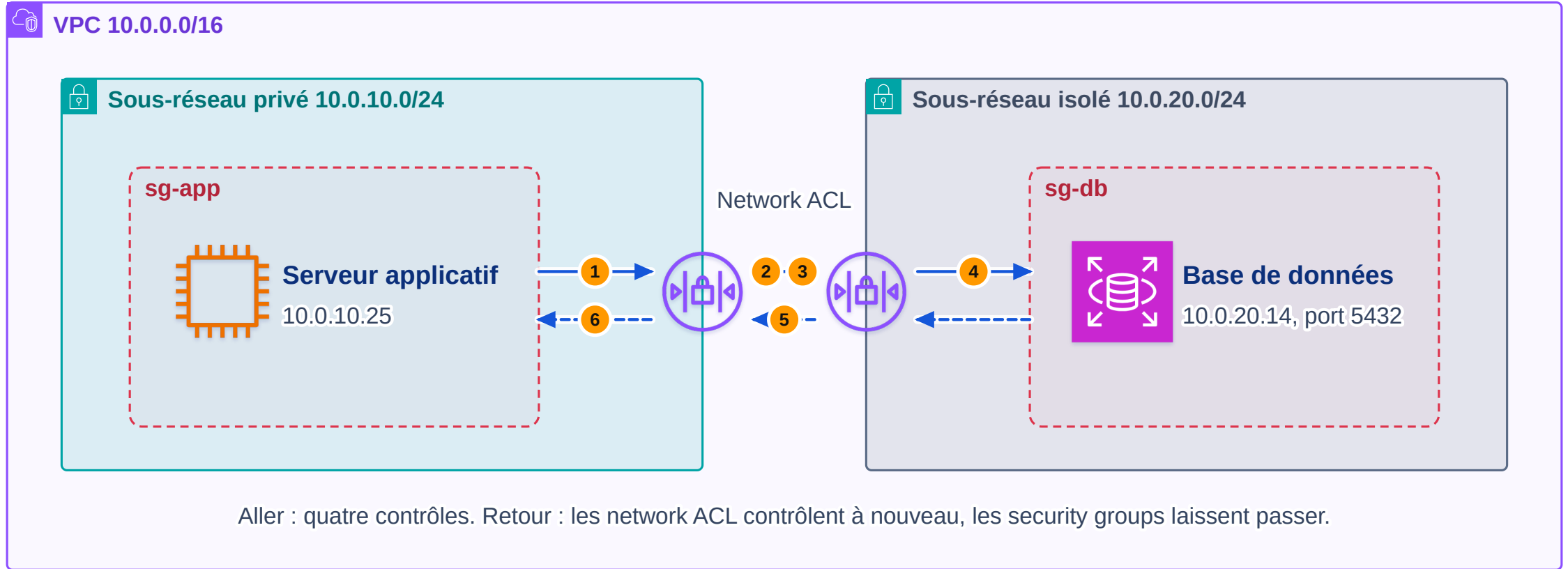
	Security group	Network ACL
Niveau	Interface réseau de la ressource.	Frontière du sous-réseau.
Règles	Autorisations seulement.	Autorisations et refus.
États	À états : les réponses passent.	Sans état : les réponses doivent être autorisées.
Évaluation	Toutes les règles ; une autorisation suffit.	Par numéro ; la première qui correspond décide.
Sources possibles	Plage, security group, liste de préfixes.	Plage uniquement.
S'applique à	Les ressources auxquelles on l'attache.	Toutes les ressources du sous-réseau, sans exception.
Trafic interne au sous-réseau	Filtré.	Non filtré.
État initial	Rien n'entre, tout sort.	Par défaut : tout passe.
Usage	Filtrage principal, précis.	Garde-fou large, refus ciblés.

Définition : défense en profondeur

Empilement de protections indépendantes : ici, le security group de la ressource et la network ACL de son sous-réseau. La défaillance de l'une ne suffit pas à exposer la ressource.

Ordre de passage. En entrée : network ACL, puis security group. En sortie : security group, puis network ACL. Les deux doivent autoriser.

Schéma : les contrôles traversés entre deux sous-réseaux



1. Règles sortantes de **sg-app**.

2. Règles sortantes de la network ACL du sous-réseau privé.

3. Règles entrantes de la network ACL du sous-réseau isolé.

4. Règles entrantes de **sg-db**.

5. Au retour, règles sortantes de la network ACL du sous-réseau isolé : ports éphémères.

6. Puis règles entrantes de celle du sous-réseau privé : ports éphémères.

Quand utiliser une network ACL

Besoin	Réponse
Bloquer une adresse ou une plage malveillante	Règle DENY de petit numéro. Un security group ne sait pas refuser.
Garantir qu'un sous-réseau isolé ne parle jamais à Internet	Network ACL qui n'autorise que les plages du VPC.
Interdire un protocole dans tout un sous-réseau	Règle DENY, quels que soient les security groups des ressources.
Exigence de conformité : deux contrôles indépendants	Network ACL en plus des security groups.
Séparer deux environnements du même VPC	Refus mutuel entre leurs sous-réseaux.

À grande échelle, le blocage d'adresses malveillantes relève plutôt d'AWS WAF (pour le web) ou d'AWS Network Firewall : une network ACL est limitée à quelques dizaines de règles.

Quand s'en passer

- Dans la majorité des cas : des security groups bien écrits suffisent.
- Laisser alors la network ACL par défaut, ouverte.
- Une network ACL mal écrite est la cause la plus difficile à trouver d'une panne réseau.

\$ Bloquer une plage en entrée d'un sous-réseau

```
# Network ACL associée au sous-réseau public
ACL=$(aws ec2 describe-network-acls \
  --filters Name=association.subnet-id,Values=$PUB_A \
  --query 'NetworkAcls[0].NetworkAclId' --output text)

# Règle 50 : passe avant la règle 100 qui autorise
aws ec2 create-network-acl-entry --network-acl-id $ACL \
  --ingress --rule-number 50 --protocol -1 \
  --cidr-block 198.51.100.0/24 --rule-action deny
```

S'entraîner : une network ACL pour les sous-réseaux isolés

Énoncé

Les sous-réseaux isolés (10.0.20.0/24 , 10.0.21.0/24) hébergent une base PostgreSQL. Seuls les sous-réseaux privés (10.0.10.0/24 , 10.0.11.0/24) doivent pouvoir la joindre. Les deux instances de la base se répliquent entre elles, d'une zone à l'autre.

Écrire la network ACL de ces sous-réseaux.

Pourquoi une règle pour 10.0.20.0/23 ?

Pourquoi les ports éphémères en sortie ?

Que manque-t-il pour les sauvegardes vers S3 ?

Une solution

Règles entrantes				
100	TCP	5432	10.0.10.0/23	ALLOW
110	TCP	5432	10.0.20.0/23	ALLOW
120	TCP	1024-65535	10.0.20.0/23	ALLOW
*	Tous	Tous	0.0.0.0/0	DENY

Règles sortantes				
100	TCP	1024-65535	10.0.10.0/23	ALLOW
110	TCP	5432	10.0.20.0/23	ALLOW
120	TCP	1024-65535	10.0.20.0/23	ALLOW
*	Tous	Tous	0.0.0.0/0	DENY

Six règles pour deux flux. Avec des security groups, le même résultat tient en deux règles entrantes. C'est la mesure concrète de ce que coûte l'absence d'état.

Erreur	Symptôme	Correction
Ports éphémères oubliés en sortie	La requête arrive, la réponse ne revient pas : délai dépassé.	Autoriser 1024-65535 en sortie.
Ports éphémères oubliés en entrée	Les ressources du sous-réseau ne peuvent plus rien joindre.	Autoriser 1024-65535 en entrée.
Refus numéroté après l'autorisation	Le refus n'a aucun effet.	Lui donner un numéro plus petit.
Network ACL personnalisée vide associée	Tout le sous-réseau est coupé.	Ajouter les règles avant d'associer.
Règle écrite dans un seul sens	Fonctionne dans un sens seulement.	Penser aller et retour, pour chaque flux.
Network ACL d'un seul des deux sous-réseaux corrigée	Blocage persistant.	Vérifier celle de la source et celle de la destination.
Oubli du DNS, du temps, des mises à jour	Pannes indirectes : noms non résolus, dérive d'horloge.	Recenser tous les flux avant de fermer.
Tenter de filtrer à l'intérieur d'un sous-réseau	Sans effet.	Utiliser les security groups.

Règle de prudence. Ne durcir une network ACL qu'après avoir activé les Flow Logs et observé le trafic réel du sous-réseau : on découvre toujours un flux auquel on n'avait pas pensé.

Filtrage et accès privés, partie 3

Le chaînage de security groups

Désigner un security group comme source d'un autre : chaque niveau n'accepte que le niveau qui le précède.

- Référencer un security group
- La chaîne load balancer, application, base
- Pourquoi c'est mieux qu'une plage d'adresses
- Les règles de UtopiosShop
- Mise en œuvre
- Administration sans port ouvert

Référencer un security group dans une règle

Définition : référence à un security group

Règle dont la source, ou la destination, n'est pas une plage d'adresses mais un autre security group : elle autorise toutes les interfaces réseau qui en sont membres.

Règle entrante de sg-db

TCP	5432	sg-app	PostgreSQL depuis l'application
-----	------	--------	---------------------------------

Lecture

« Autoriser le port 5432 depuis toute ressource qui porte le security group `sg-app`. » Peu importe son adresse, son sous-réseau ou sa zone.

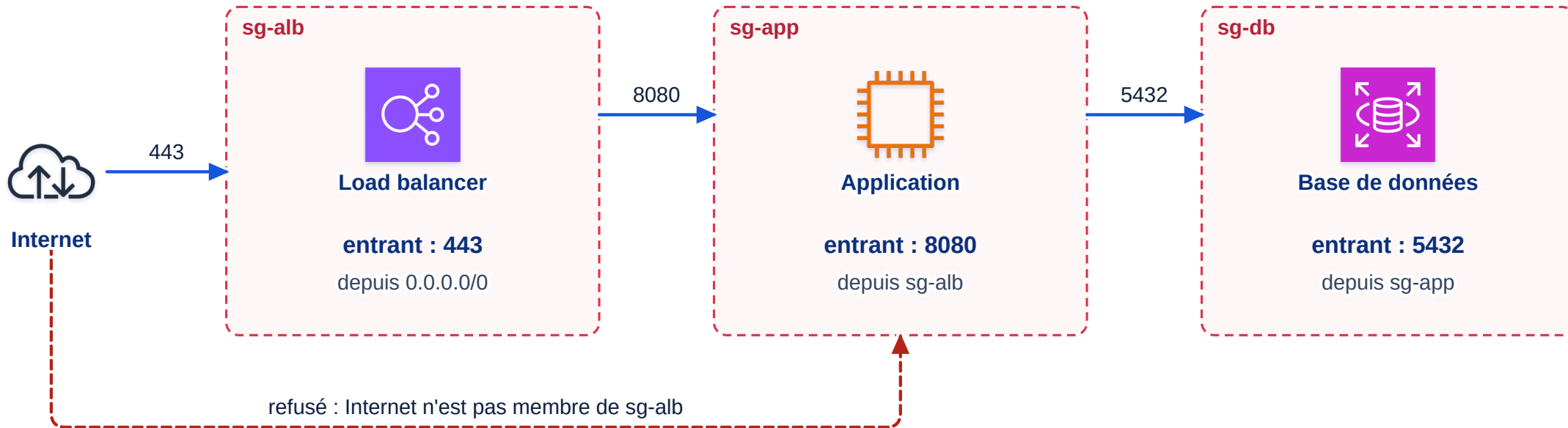
Ce que la règle ne dit pas. Elle n'ajoute aucune règle à `sg-app`, et ne « fusionne » rien : elle se contente d'identifier une source par son appartenance.

Ce que cela change

- **Suivi automatique** : une instance lancée par l'Auto Scaling avec `sg-app` est autorisée à l'instant, sans toucher aux règles.
- **Précision** : seules les ressources de ce rôle passent, pas leurs voisines de sous-réseau.
- **Lisibilité** : la règle dit l'intention, « l'application parle à la base », pas une adresse.
- **Stabilité** : rien à corriger quand les adresses changent.

Portée. La référence fonctionne dans un même VPC, et entre deux VPC reliés par peering dans la même région. La correspondance se fait sur les adresses **privées** des membres.

Schéma : la chaîne load balancer, application, base



Définition : chaînage de security groups

Montage dans lequel chaque security group n'accepte, en entrée, que le security group du niveau qui le précède.

Lecture. Internet ne peut joindre que le load balancer, sur le port 443. Le load balancer est le seul à pouvoir joindre l'application, sur le port 8080. L'application est la seule à pouvoir joindre la base, sur le port 5432. Une tentative directe d'Internet vers l'application est refusée, même si l'application se trouvait par erreur dans un sous-réseau public.

Chaînage

Les trois security groups de UtopiosShop

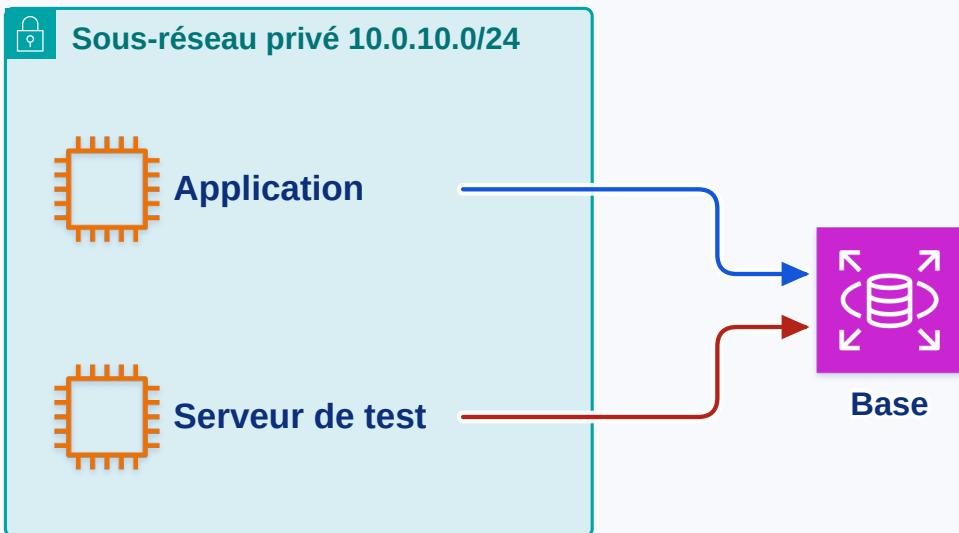
Security group	Sens	Port	Source ou destination	Raison
sg-alb	Entrant	443	0.0.0.0/0	Les clients, depuis Internet.
	Sortant	8080	sg-app	Transmettre les requêtes à l'application, et vérifier sa santé.
sg-app	Entrant	8080	sg-alb	Seul le load balancer peut appeler l'application.
	Sortant	5432	sg-db	Joindre la base.
	Sortant	443	0.0.0.0/0	API externes, mises à jour, services AWS.
sg-db	Entrant	5432	sg-app	Seule l'application peut joindre la base. Aucune règle sortante utile.

Règles sortantes. Par défaut, un security group autorise toute sortie. Les resserrer, comme ici, est un renforcement facultatif : une instance compromise ne peut alors joindre que ce qui est prévu. Beaucoup d'équipes commencent par les règles entrantes, et resserrent la sortie ensuite.

Aucune adresse IP interne. Dans tout le tableau, la seule plage est 0.0.0.0/0 . Le plan d'adressage peut changer, une zone s'ajouter : ces règles restent justes.

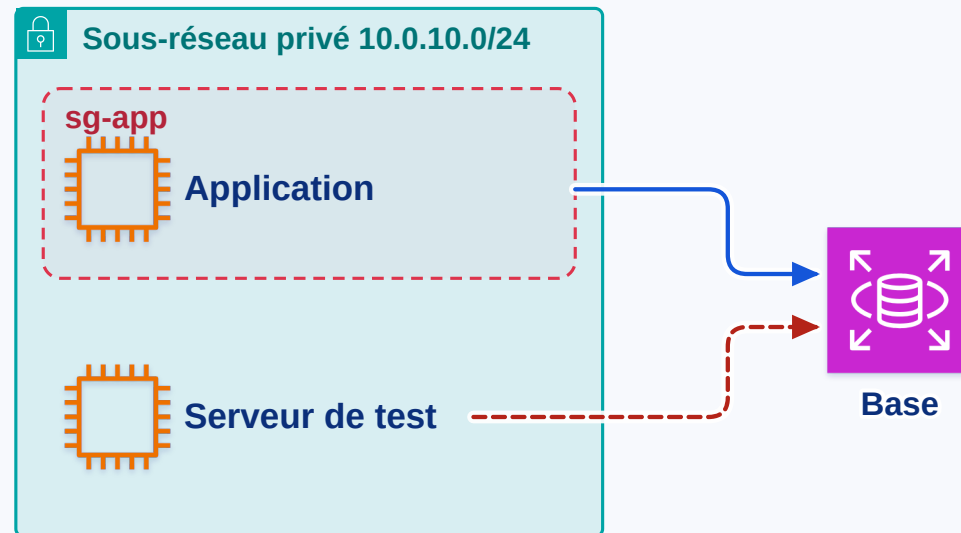
Schéma : une plage d'adresses ou un security group

Source de la règle : la plage 10.0.10.0/24



Tout le sous-réseau atteint la base,
serveur de test compris.

Source de la règle : sg-app



Seuls les membres de sg-app atteignent la base.
Le serveur de test est refusé.

Le défaut de la plage. Autoriser `10.0.10.0/24`, c'est autoriser tout ce qui se trouve ou se trouvera dans ce sous-réseau : un serveur de test, un bastion, un conteneur sans rapport. La compromission de l'un d'eux ouvre la base.

Moindre privilège appliqué au réseau. La référence à un security group accorde l'accès à un rôle, pas à un emplacement. C'est l'équivalent, pour le réseau, d'une politique IAM qui nomme la ressource au lieu d'écrire une étoile.

Ligne de commande : chaîner trois security groups

```
$ Prérequis : VPC_ID défini, et SG_ALB créé (voir la partie sur les security groups)

# 1. Créer les security groups de l'application et de la base
SG_APP=$(aws ec2 create-security-group --group-name user7-sg-app --description "Serveurs applicatifs" \
--vpc-id $VPC_ID --query GroupId --output text)
SG_DB=$(aws ec2 create-security-group --group-name user7-sg-db --description "Base de donnees" \
--vpc-id $VPC_ID --query GroupId --output text)

# 2. L'application accepte le port 8080 depuis le load balancer uniquement
aws ec2 authorize-security-group-ingress --group-id $SG_APP \
--protocol tcp --port 8080 --source-group $SG_ALB

# 3. La base accepte le port 5432 depuis l'application uniquement
aws ec2 authorize-security-group-ingress --group-id $SG_DB \
--protocol tcp --port 5432 --source-group $SG_APP

# 4. Vérifier la chaîne : pour chaque security group, port ouvert et source
for SG in $SG_ALB $SG_APP $SG_DB; do
  aws ec2 describe-security-group-rules --filters Name=group-id,Values=$SG \
    --query 'SecurityGroupRules[?!IsEgress].[GroupId,FromPort,CidrIpv4,ReferencedGroupInfo.GroupId]' --output text
done

# 5. Qui référence sg-app ? (à consulter avant de le supprimer)
aws ec2 describe-security-groups --filters Name=ip-permission.group-id,Values=$SG_APP \
--query 'SecurityGroups[][GroupId,GroupName]' --output table
```

Suppression. Un security group référencé par un autre ne peut pas être supprimé : il faut d'abord retirer la règle qui le cite. C'est l'erreur `DependencyViolation` la plus fréquente au nettoyage d'un VPC.

Security group qui se référence lui-même

Règle entrante dont la source est le security group lui-même : ses membres peuvent se parler entre eux.

Usage : nœuds d'un cluster qui doivent communiquer (cache, base répliquée, nœuds Kubernetes).

C'est la règle du security group par défaut ; utile, à condition de la limiter aux ports nécessaires.

Security group « client »

Un security group sans aucune règle, `sg-db-clients`, sert uniquement de badge : la base autorise ce badge.

Usage : donner l'accès à la base à plusieurs applications, sans citer chacune dans `sg-db`. On accorde l'accès en attachant le badge.

Liste de préfixes

Une liste nommée de plages, gérée à un seul endroit et citée dans plusieurs règles.

Usage : les adresses des bureaux de l'entreprise, ou celles d'un service AWS : la liste fournie pour CloudFront permet de n'accepter que le trafic passé par le CDN.

Limite à connaître. Une règle qui référence un security group ne s'applique pas au trafic qui arrive par l'adresse publique des membres, ni à celui qui traverse une NAT Gateway : la correspondance porte sur les adresses privées, à l'intérieur du VPC.

	SSH par bastion	Session Manager
Port entrant	22 ouvert sur le bastion.	Aucun.
Adresse publique	Sur le bastion.	Aucune.
Identifiants	Clés SSH à distribuer et à révoquer.	Droits IAM.
Traçabilité	À mettre en place.	Sessions journalisées dans CloudTrail, contenu enregistrable.
Serveur à maintenir	Le bastion.	Aucun.

Définition : Session Manager

Fonction de AWS Systems Manager qui ouvre une session de terminal sur une instance par l'intermédiaire d'un agent, sans port entrant ni clé SSH.

Pourquoi aucun port n'est nécessaire

- L'agent installé sur l'instance ouvre lui-même une connexion **sortante**, en HTTPS, vers Systems Manager.
- L'administrateur se connecte à Systems Manager, qui relaie la session dans ce canal.
- Le security group de l'instance n'a donc besoin d'aucune règle entrante pour l'administration.

Trois conditions

1. L'agent SSM tourne sur l'instance : préinstallé sur Amazon Linux et la plupart des images.
2. Le rôle de l'instance porte `AmazonSSMManagedInstanceCore`.
3. L'instance peut joindre Systems Manager en HTTPS : par une NAT Gateway, ou par des VPC endpoints.

Chaînage

S'entraîner : qui peut joindre qui

Security group	Règles entrantes
sg-alb	443 depuis 0.0.0.0/0
sg-app	8080 depuis sg-alb
sg-db	5432 depuis sg-app
sg-admin	aucune

Toutes les règles sortantes sont laissées ouvertes. Les network ACL sont celles par défaut. Les routes sont en place.

1. Un client sur Internet peut-il joindre l'application sur le port 8080 ?

2. Le load balancer peut-il joindre la base sur le port 5432 ?

3. L'application peut-elle joindre la base sur le port 3306 ?

4. La base peut-elle ouvrir une connexion vers l'application sur le port 8080 ?

5. Deux serveurs applicatifs, tous deux dans sg-app, peuvent-ils se parler sur le port 8080 ?

6. Une instance porte sg-app et sg-admin. Peut-elle joindre la base ?

7. On lance un nouveau serveur applicatif dans un autre sous-réseau, avec sg-app. Faut-il modifier une règle ?

8. Le serveur applicatif répond-il au ping du load balancer ?

Cliquer sur une question pour afficher la réponse.

Erreur	Symptôme	Correction
La source cite le security group de la ressource elle-même au lieu de celui de l'appelant	La connexion expire.	La source est le security group de celui qui appelle .
Le load balancer n'est pas dans sg-alb	Erreurs 504 : il ne joint pas l'application.	Vérifier les security groups réellement attachés.
Port de la règle différent du port d'écoute	Délai dépassé.	Aligner la règle sur le port réel de l'application.
Contrôles de santé oubliés	Cibles « unhealthy » alors que l'application fonctionne.	Autoriser aussi le port de santé depuis sg-alb.
Règle sortante resserrée sans prévoir le DNS ni les services AWS	Pannes indirectes.	Recenser les flux sortants avant de fermer.
Référence à un security group d'un autre VPC non relié	Règle refusée à la création.	Utiliser une plage, ou relier les VPC.
Suppression d'un security group encore référencé	DependencyViolation .	Retirer d'abord les règles qui le citent.

Vérification rapide. Pour un flux de A vers B sur le port P : le security group de B a-t-il une règle entrante sur P dont la source inclut A ? Le security group de A laisse-t-il sortir vers B sur P ? Deux questions, toujours les mêmes.

Filtrage et accès privés, partie 4

Les VPC endpoints

Joindre S3 et les autres services AWS depuis un sous-réseau privé, sans passer par Internet ni par la NAT Gateway.

- Le problème : les API d'AWS sont publiques
- Deux types d'endpoints
- L'endpoint passerelle
- L'endpoint d'interface et PrivateLink
- DNS privé, politique, coût
- Un sous-réseau sans aucune sortie

Le problème : les API d'AWS sont sur Internet

S3, DynamoDB, CloudWatch, Secrets Manager, ECR : tous ces services se joignent par des adresses publiques. Vu d'un VPC, ils sont « dehors ».

Conséquences sans endpoint

- Une instance d'un sous-réseau **privé** les atteint par la NAT Gateway : chaque gigaoctet y est facturé.
- Une instance d'un sous-réseau **isolé** ne les atteint pas du tout.
- Le trafic sort du VPC par l'Internet Gateway, même s'il reste sur le réseau d'AWS.

Définition : VPC endpoint

Point d'accès privé, créé dans un VPC, qui permet à ses ressources de joindre un service AWS sans Internet Gateway, sans NAT Gateway et sans adresse publique.

Ce qu'un endpoint apporte

- **Sécurité** : le trafic ne quitte pas le réseau privé d'AWS.
- **Coût** : il évite les frais de traitement de la NAT Gateway.
- **Contrôle** : une politique d'endpoint limite ce qui peut être atteint.
- **Indépendance** : un sous-réseau peut se passer de toute sortie vers Internet.

Rien ne change dans le code. L'application appelle S3 comme avant, avec le même nom et les mêmes identifiants : seul le chemin réseau diffère.

Deux types d'endpoints

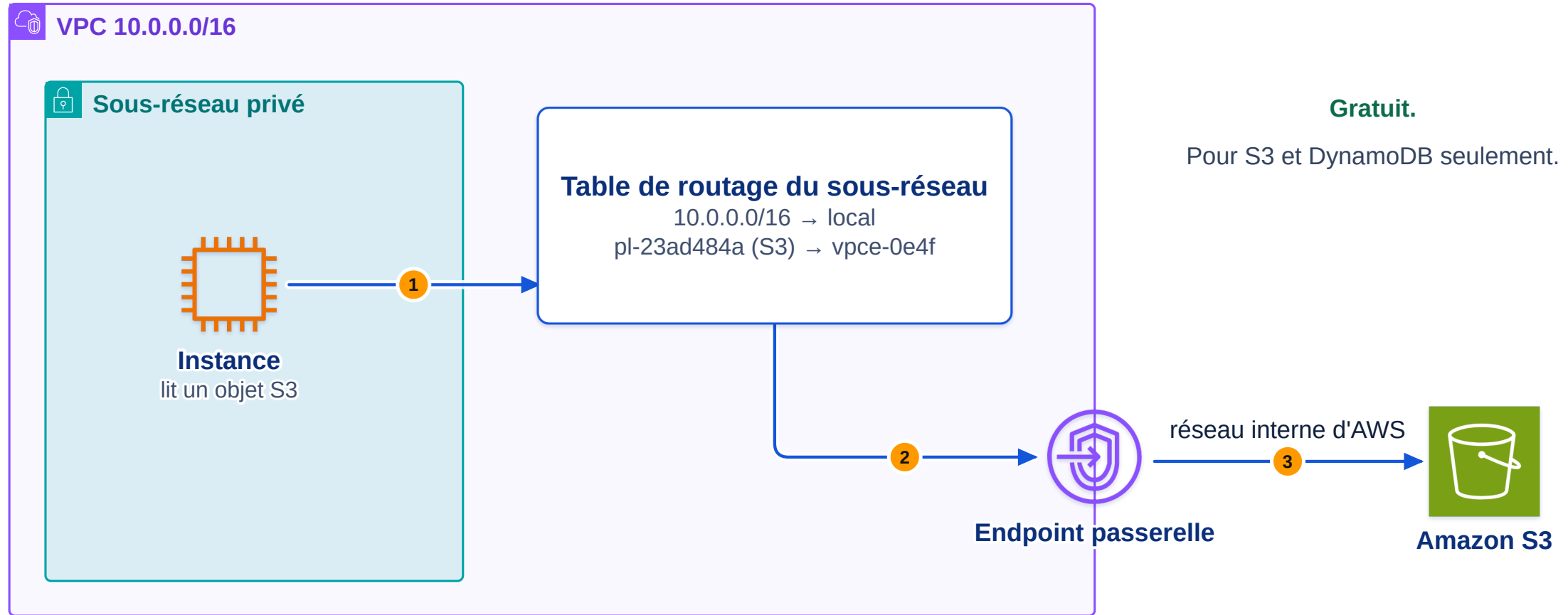
	Endpoint passerelle (gateway)	Endpoint d'interface
Services	S3 et DynamoDB uniquement.	Presque tous les services AWS, S3 compris.
Forme	Une cible dans les tables de routage.	Une interface réseau, avec une adresse privée, dans vos sous-réseaux.
Mécanisme	Routage : une route vers la liste de préfixes du service.	DNS : le nom du service donne l'adresse privée de l'interface.
Filtrage	Politique d'endpoint.	Politique d'endpoint et security group.
Coût	Gratuit.	À l'heure, par zone, et au gigaoctet.
Accessible depuis	Le VPC seulement.	Le VPC, et les réseaux qui lui sont reliés (VPN, Direct Connect, peering).
Disponibilité	Régionale, sans rien à prévoir.	Une interface par zone à créer.

Définition : AWS PrivateLink

Technologie sur laquelle reposent les endpoints d'interface : elle expose un service, d'AWS ou d'un tiers, sous la forme d'interfaces réseau privées dans votre VPC.

Règle simple. Pour S3 et DynamoDB : l'endpoint passerelle, toujours, puisqu'il est gratuit. Pour les autres services : l'endpoint d'interface, quand le volume ou l'isolement le justifie.

Schéma : l'endpoint passerelle



1. L'instance appelle S3 par son nom habituel ; le DNS renvoie une adresse publique de S3.
2. La table de routage contient une route vers la liste de préfixes de S3 : plus précise que la route par défaut, elle l'emporte et désigne l'endpoint.
3. Le trafic rejoint S3 par le réseau interne d'AWS, sans NAT Gateway ni Internet Gateway.

```
$ Prérequis : VPC_ID et les tables de routage privées (RT_PRIV_A) définis

# Créer l'endpoint S3 et l'inscrire dans la table privée
aws ec2 create-vpc-endpoint --vpc-id $VPC_ID \
  --service-name com.amazonaws.eu-west-3.s3 \
  --route-table-ids $RT_PRIV_A \
  --tag-specifications \
  'ResourceType=vpc-endpoint,Tags=[{Key=Name,Value=user7-vpce-s3}]'

# La route ajoutée automatiquement
aws ec2 describe-route-tables --route-table-ids $RT_PRIV_A \
  --query 'RouteTables[0].Routes[][DestinationPrefixListId,GatewayId]' \
  --output text

# Les plages que recouvre la liste de préfixes de S3
aws ec2 describe-managed-prefix-lists \
  --filters Name=prefix-list-name,Values=com.amazonaws.eu-west-3.s3 \
  --query 'PrefixLists[0].PrefixListId' --output text
```

Définition : endpoint passerelle (gateway endpoint)

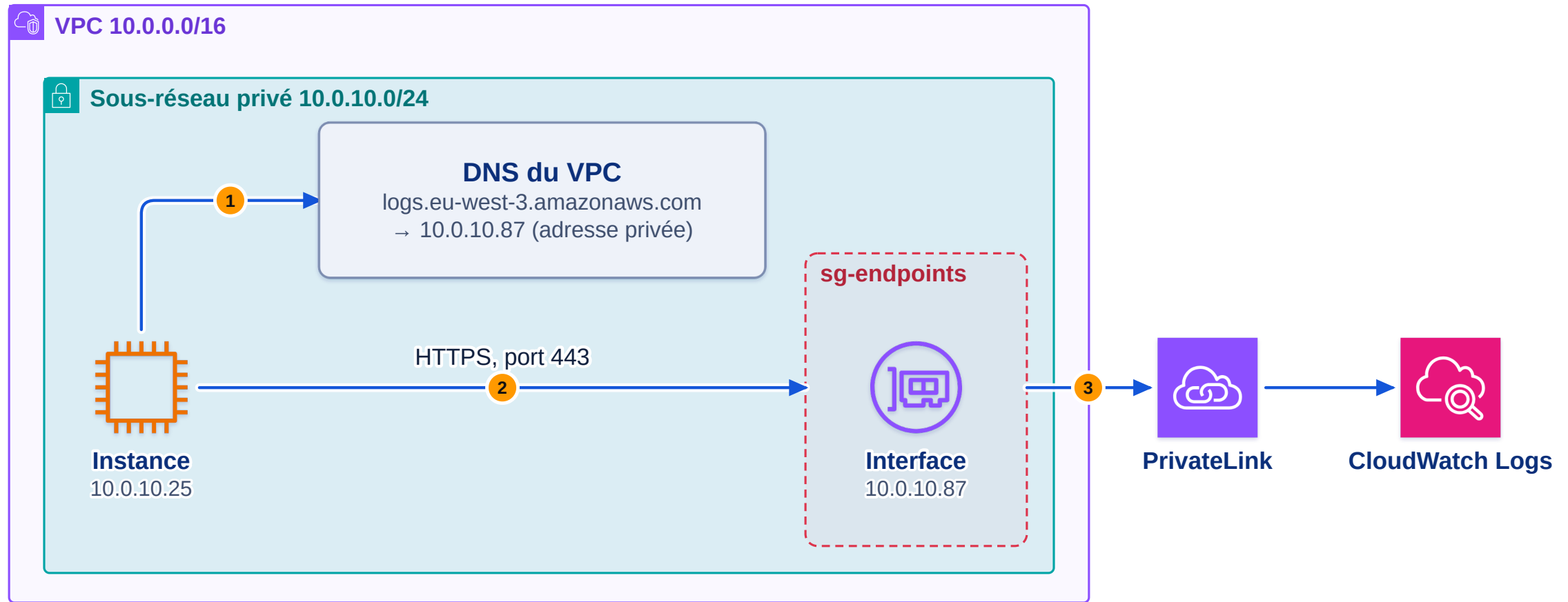
VPC endpoint qui prend la forme d'une cible de routage. Il existe pour S3 et DynamoDB, et ne coûte rien.

À savoir

- Le type par défaut de la commande est « Gateway ».
- On choisit les **tables de routage** concernées : seuls les sous-réseaux associés à ces tables utilisent l'endpoint.
- AWS ajoute et tient à jour la route ; on ne la crée pas à la main.
- Il ne sert que la région du VPC : un bucket d'une autre région reste joint par Internet.
- Dans un security group, la liste de préfixes peut servir de destination pour n'autoriser que S3 en sortie.

Oubli fréquent. Créer l'endpoint sans l'associer à la table du sous-réseau concerné : il existe, mais personne ne l'emprunte. Vérifier la présence d'une route `pl-...` dans la table.

Schéma : l'endpoint d'interface



1. L'instance demande l'adresse du service. Grâce au DNS privé de l'endpoint, le résolveur du VPC renvoie une adresse privée du sous-réseau.

2. Elle se connecte à cette adresse en HTTPS : le security group de l'endpoint doit autoriser le port 443 depuis elle.

3. L'interface transmet au service par PrivateLink, sans jamais sortir du réseau d'AWS.

Définition : endpoint d'interface

VPC endpoint qui prend la forme d'une interface réseau dotée d'une adresse privée, dans vos sous-réseaux. Il existe pour la plupart des services.

Trois éléments à fournir

- **Les sous-réseaux** : une interface est créée dans chacun, donc dans chaque zone choisie.
- **Un security group** : il doit accepter le port 443 depuis les ressources clientes.
- **Le DNS privé** : activé, il fait pointer le nom standard du service vers l'endpoint.

Définition : DNS privé d'un endpoint

Option qui fait résoudre, à l'intérieur du VPC, le nom public habituel du service vers les adresses privées de l'endpoint. Les applications n'ont alors rien à modifier.

Le DNS privé exige les deux options DNS du VPC : **DNS resolution** et **DNS hostnames**.

\$ Prérequis : VPC_ID, PRIV_A et PRIV_B définis

```
# Security group de l'endpoint : HTTPS depuis le VPC
SG_VPCE=$(aws ec2 create-security-group \
  --group-name user7-sg-endpoints \
  --description "Endpoints d interface" \
  --vpc-id $VPC_ID --query GroupId --output text)
aws ec2 authorize-security-group-ingress \
  --group-id $SG_VPCE --protocol tcp --port 443 \
  --cidr 10.0.0.0/16
```

```
# Endpoint d'interface pour CloudWatch Logs
aws ec2 create-vpc-endpoint --vpc-id $VPC_ID \
  --vpc-endpoint-type Interface \
  --service-name com.amazonaws.eu-west-3.logs \
  --subnet-ids $PRIV_A $PRIV_B \
  --security-group-ids $SG_VPCE \
  --private-dns-enabled
```

```
# Depuis une instance : le nom donne une adresse privée
dig +short logs.eu-west-3.amazonaws.com
```

aws

VPC > Endpoints > Create endpoint

Name tag

user7-vpce-logs

Type

☒ AWS services

Services

com.amazonaws.eu-west-3.logs (Interface) ▼

VPC

user7-vpc ▼

Enable DNS name

☒ Enable for this endpoint

Subnets

☒ eu-west-3a : subnet-prive-a, eu-west-3b : subnet-prive-b

Security groups

☒ user7-sg-endpoints

Policy

☒ Full access

Create endpoint

Champ	À surveiller
Services	La colonne « Type » distingue Gateway et Interface. S3 apparaît deux fois : choisir Gateway, sauf besoin particulier.
Enable DNS name	C'est le DNS privé : à cocher pour que les applications n'aient rien à changer.
Subnets	Un par zone utilisée. Pour un endpoint passerelle, ce champ est remplacé par la liste des tables de routage.
Security groups	Doit accepter le port 443 depuis les clients. Absent pour un endpoint passerelle.
Policy	« Full access » par défaut ; « Custom » pour restreindre.

État. L'endpoint passe de « Pending » à « Available » en une à deux minutes. Tant qu'il est en attente, le nom du service continue de pointer vers Internet.

Facturation. Un endpoint d'interface est facturé dès sa création, pour chaque zone choisie : le supprimer après un essai.

Définition : politique d'endpoint

Politique de ressource attachée à un VPC endpoint, qui limite les actions et les ressources accessibles à travers lui. Elle ne donne aucun droit : elle restreint.

`{}` N'autoriser, par cet endpoint, que le bucket de l'application

```
{
  "Version": "2012-10-17",
  "Statement": [ {
    "Effect": "Allow",
    "Principal": "*",
    "Action": ["s3:GetObject", "s3:PutObject",
              "s3:ListBucket"],
    "Resource": [
      "arn:aws:s3:::shop-images",
      "arn:aws:s3:::shop-images/*"
    ]
  } ]
}
```

À quoi elle sert

- Empêcher qu'une instance du VPC envoie des données vers un bucket étranger, même avec des identifiants valides : c'est une protection contre l'exfiltration.
- Réserver l'endpoint à certains rôles ou à certaines actions.

Comment elle s'articule avec IAM

Elle s'ajoute aux autres contrôles : pour qu'une requête passe, il faut que la politique d'identité, la politique du bucket **et** la politique d'endpoint l'autorisent.

Par défaut, la politique d'un endpoint autorise tout : elle ne restreint rien tant qu'on ne l'écrit pas.

L'inverse existe. Une politique de bucket peut exiger que les requêtes arrivent par un endpoint précis, avec la clé de condition `aws:sourceVpce` : le bucket devient inaccessible hors du VPC.

Le coût, et l'arbitrage avec la NAT Gateway

Élément	Tarif indicatif
Endpoint passerelle	Gratuit.
Endpoint d'interface, par zone	0,01 \$ par heure, soit environ 7,30 \$ par mois.
Données par endpoint d'interface	0,01 \$ par Go.
Rappel : NAT Gateway	0,045 \$ par heure et 0,045 \$ par Go.

Tarifs de la région us-east-1, hors taxes ; légèrement supérieurs à Paris.

Situation	Choix
Trafic vers S3 ou DynamoDB	Endpoint passerelle, sans hésiter.
Gros volume vers un service (images ECR, journaux)	Endpoint d'interface : rentable au-delà de quelques centaines de Go par mois.
Faible volume, vers de nombreux services	NAT Gateway : un seul coût fixe pour tout.
Sous-réseau qui ne doit avoir aucune sortie	Endpoints d'interface, seuls.
Besoin d'API tierces sur Internet	NAT Gateway indispensable ; les endpoints la soulagent.

Lecture. Un endpoint d'interface sur deux zones coûte environ 15 \$ par mois avant tout trafic. Au gigaoctet, il est quatre à cinq fois moins cher que la NAT.

Le piège du nombre. Dix endpoints d'interface sur trois zones coûtent plus de 200 \$ par mois : davantage que les NAT Gateway qu'ils devaient remplacer. On ne crée que ceux qui servent.

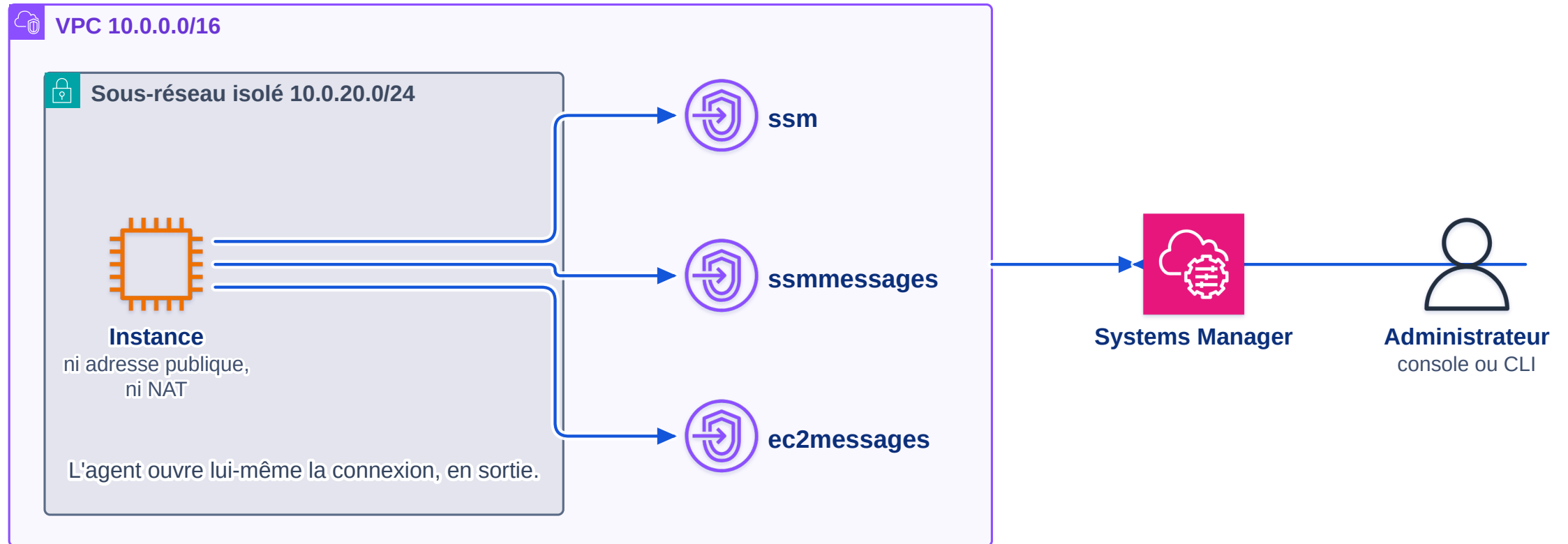
Quels endpoints pour un sous-réseau sans sortie

Besoin	Endpoints nécessaires	Type
Lire et écrire dans S3	s3	Passerelle
Accéder à DynamoDB	dynamodb	Passerelle
Session Manager	ssm , ssmmessages , et ec2messages pour les agents anciens	Interface
Tirer des images de conteneurs depuis ECR	ecr.api , ecr.dkr , et s3 pour les couches d'image	Interface et passerelle
Envoyer des journaux à CloudWatch	logs	Interface
Lire des secrets	secretsmanager	Interface
Endosser un rôle	sts	Interface
Chiffrer avec une clé gérée	kms	Interface

Nom complet d'un service. `com.amazonaws.<région>.<service>` , par exemple `com.amazonaws.eu-west-3.ssmmessages` . La liste se consulte avec `aws ec2 describe-vpc-endpoint-services` .

Un service oublié se manifeste par un délai dépassé au moment où l'application l'appelle, souvent bien après le démarrage. Les Flow Logs montrent alors vers quelle adresse publique elle tentait de sortir.

Schéma : administrer une instance isolée



Lecture. L'instance n'a ni adresse publique, ni route vers Internet, ni port entrant ouvert. Son agent joint Systems Manager par les endpoints du VPC ; l'administrateur ouvre sa session depuis la console ou la CLI, avec ses droits IAM.

Ce que l'on obtient. Une machine administrable, mise à jour par des dépôts hébergés dans S3, et totalement invisible d'Internet. C'est la cible pour les serveurs qui traitent des données sensibles.

Erreur	Symptôme	Correction
Endpoint passerelle non associé à la table de routage du sous-réseau	Le trafic continue par la NAT, ou n'aboutit pas.	Ajouter la table à l'endpoint.
Security group de l'endpoint d'interface sans règle 443	Délai dépassé vers le service.	Autoriser 443 depuis les clients.
DNS privé désactivé	Le nom du service donne toujours une adresse publique.	Activer l'option, et les options DNS du VPC.
Endpoint créé dans une seule zone	Dépendance à cette zone.	Un sous-réseau par zone utilisée.
Politique d'endpoint trop stricte	<code>AccessDenied</code> inattendu.	Lire le message : il nomme la politique d'endpoint.
Bucket d'une autre région	L'endpoint passerelle n'est pas emprunté.	Normal : il ne sert que sa région.
Endpoints d'interface créés puis oubliés	Coût fixe mensuel.	Étiquettes, revue, suppression.
Service manquant dans un sous-réseau isolé	Panne tardive et partielle.	Recenser tous les services appelés.

Vérifier le chemin emprunté. Depuis l'instance, `dig +short` sur le nom du service : une adresse en `10.x` signifie endpoint d'interface. Pour S3 par endpoint passerelle, l'adresse reste publique : c'est la table de routage qu'il faut regarder.

Filtrage et accès privés, partie 5

Les VPC Flow Logs

Le journal de ce qui circule vraiment dans le VPC : qui a parlé à qui, sur quel port, et si le trafic a été accepté.

- Définition et périmètre
- Niveaux de capture et destinations
- Anatomie d'un enregistrement
- Lire ACCEPT et REJECT
- Activer et interroger
- Coût et bonnes pratiques

Que sont les VPC Flow Logs

Définition : VPC Flow Logs

Fonction qui enregistre les métadonnées du trafic IP entrant et sortant des interfaces réseau d'un VPC : adresses, ports, protocole, volume, et décision d'acceptation ou de rejet.

À quoi ils servent

- **Dépanner** : voir si un paquet arrive, et s'il est accepté ou rejeté.
- **Vérifier le filtrage** : une règle trop large ou trop stricte se lit dans les journaux.
- **Surveiller** : repérer des balayages de ports, des destinations inhabituelles.
- **Comprendre les coûts** : qui consomme la NAT Gateway, quel flux traverse les zones.
- **Répondre à un audit** : conserver la trace des communications.

Enregistré	Non enregistré
Adresses et ports, source et destination.	Le contenu des paquets.
Protocole, nombre de paquets et d'octets.	Les requêtes au résolveur DNS d'AWS.
Décision : ACCEPT ou REJECT .	Les appels au service de métadonnées (169.254.169.254).
Interface, début et fin de la fenêtre.	Le trafic DHCP et la synchronisation d'horloge d'AWS.

Ce ne sont pas des captures de paquets. Un flow log dit qu'une connexion a eu lieu, pas ce qu'elle transportait. Pour le contenu, il existe une autre fonction, le Traffic Mirroring.

Niveau	Capture
VPC	Toutes les interfaces du VPC, présentes et futures.
Sous-réseau	Toutes les interfaces du sous-réseau.
Interface réseau	Une seule interface : une instance, un endpoint, une NAT Gateway.

Filtre	Trafic retenu
ALL	Accepté et rejeté.
ACCEPT	Accepté seulement.
REJECT	Rejeté seulement : utile et économique pour la sécurité.

Destination	Usage
CloudWatch Logs	Recherche interactive, requêtes Logs Insights, alarmes. Le plus pratique pour dépanner.
Amazon S3	Conservation longue et peu coûteuse ; analyse avec Athena.
Data Firehose	Envoi vers un outil d'analyse ou de sécurité tiers.

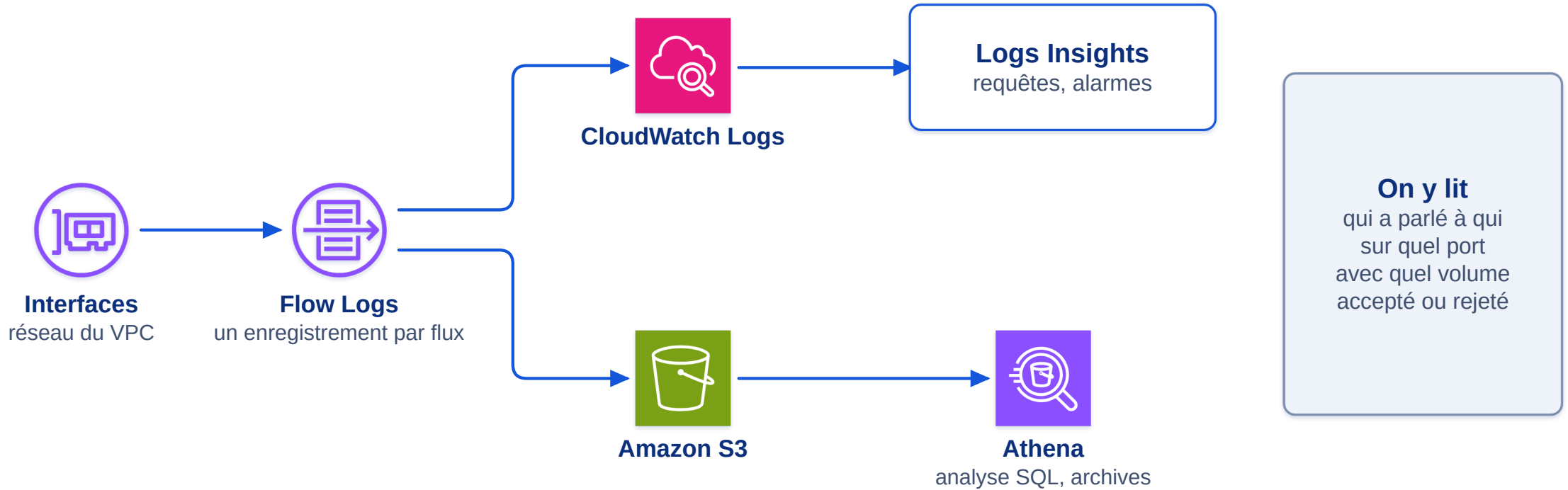
Définition : fenêtre d'agrégation

Durée pendant laquelle les paquets d'un même flux sont regroupés en un seul enregistrement : 10 minutes par défaut, 1 minute sur demande.

Délai. Les flux sont agrégés par fenêtres de 10 minutes par défaut, ou d'une minute sur demande, puis livrés avec quelques minutes de retard. Ce n'est pas du temps réel : après un test, il faut patienter avant de lire le résultat.

Sans effet sur le trafic. La capture se fait hors du chemin des paquets : elle ne ralentit rien et ne peut rien bloquer.

Schéma : le circuit des Flow Logs



Lecture. Chaque interface réseau produit des enregistrements. Selon la destination choisie, on les interroge de façon interactive dans CloudWatch Logs, ou on les archive dans S3 pour des analyses plus lourdes. Les deux peuvent coexister.

Choix courant. CloudWatch Logs avec une rétention courte pour le dépannage quotidien ; S3 pour la conservation exigée par la conformité.

Schéma : anatomie d'un enregistrement

2 123456789012 eni-0a1b2c3d 203.0.113.12 10.0.0.25 49152 443 6 20 4249 1759665600 1759665660 ACCEPT OK



Autres champs : version, compte, nombre de paquets et d'octets, début et fin de la fenêtre, état de la capture.

Aucun contenu : seulement les métadonnées de la connexion.

Définition : flux (flow)

Ensemble des paquets qui partagent les mêmes adresses source et destination, les mêmes ports et le même protocole, pendant une fenêtre de capture. Un enregistrement décrit un flux.

Protocoles. Le champ est un numéro : **6** pour TCP, **17** pour UDP, **1** pour ICMP. Les deux nombres longs sont des dates au format Unix, en secondes.

Les champs du format par défaut

Champ	Exemple	Signification
version	2	Version du format.
account-id	123456789012	Compte propriétaire de l'interface.
interface-id	eni-0a1b2c3d	Interface réseau observée.
srcaddr, dstaddr	203.0.113.12, 10.0.0.25	Adresses source et destination. Pour l'interface, toujours son adresse privée .
srcport, dstport	49152, 443	Ports source et destination.
protocol	6	Numéro de protocole.
packets, bytes	20, 4249	Volume échangé pendant la fenêtre.
start, end	1759665600, 1759665660	Début et fin de la fenêtre.
action	ACCEPT	Décision des security groups et network ACL.
log-status	OK	État de la capture : OK, NODATA (aucun trafic), SKIPDATA (enregistrements perdus).

Champs supplémentaires. Un format personnalisé peut ajouter l'identifiant du VPC et du sous-réseau, les drapeaux TCP, le sens du flux (`flow-direction`), ou les adresses réelles derrière une NAT (`pkt-srcaddr` , `pkt-dstaddr`).

Le format se choisit à la création et ne se modifie plus : pour l'enrichir, il faut créer un nouveau flow log.

Lire ACCEPT et REJECT

txt Trois enregistrements de l'interface eni-0a1b2c3d (adresse privée 10.0.0.25)

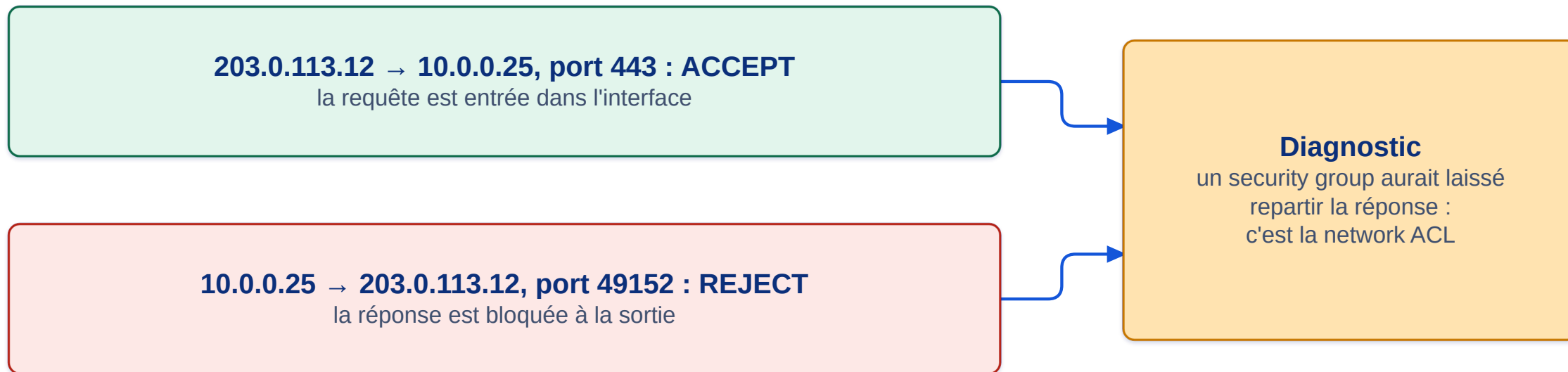
```
2 123456789012 eni-0a1b2c3d 203.0.113.12 10.0.0.25 49152 443 6 20 4249 1759665600 1759665660 ACCEPT OK
2 123456789012 eni-0a1b2c3d 10.0.0.25 203.0.113.12 443 49152 6 18 9120 1759665600 1759665660 ACCEPT OK
2 123456789012 eni-0a1b2c3d 198.51.100.7 10.0.0.25 44844 22 6 1 40 1759665600 1759665660 REJECT OK
```

Ligne	Ce qu'elle dit	Interprétation
1	203.0.113.12 a joint le port 443 de l'instance : accepté.	Un client a ouvert une connexion HTTPS.
2	L'instance a répondu depuis son port 443 vers le port 49152 du client : accepté.	La réponse est repartie : la connexion a fonctionné.
3	198.51.100.7 a tenté le port 22 : rejeté, un seul paquet de 40 octets.	Tentative SSH bloquée par le filtrage. Bruit de fond habituel d'Internet.

Aller et retour. Une connexion réussie produit deux enregistrements : un dans chaque sens, avec les ports inversés.

Qui a rejeté ? Le flow log ne nomme pas le composant. Il dit seulement que le security group ou la network ACL a refusé. La combinaison des lignes permet souvent de trancher, comme le montre la diapositive suivante.

Schéma : requête acceptée, réponse rejetée



Cause habituelle : règle sortante manquante sur les ports éphémères (1024 à 65535).

Le raisonnement. Si le security group avait bloqué, c'est la requête entrante qui serait rejetée. Elle est acceptée ; et un security group, à états, laisse toujours repartir la réponse. Le rejet au retour ne peut donc venir que d'un filtre sans état : la network ACL.

Trois signatures à connaître. Entrée rejetée : security group ou network ACL en entrée. Entrée acceptée et sortie rejetée : network ACL en sortie. Aucun enregistrement : le paquet n'est jamais arrivé jusqu'à l'interface.

S'entraîner : lire des enregistrements

txt Interface eni-0db1 de la base (adresse privée 10.0.20.14). Champs : source, destination, port source, port destination, protocole, paquets, octets, décision

A	10.0.10.25	10.0.20.14	41022	5432	6	12	1840	ACCEPT
B	10.0.20.14	10.0.10.25	5432	41022	6	10	5210	ACCEPT
C	10.0.11.40	10.0.20.14	50310	5432	6	3	180	REJECT
D	10.0.10.25	10.0.20.14	41050	22	6	1	60	REJECT
E	10.0.20.14	52.95.110.8	38211	443	6	4	240	ACCEPT

1. Que montrent les lignes A et B ?

2. Que s'est-il passé à la ligne C ?

3. Et à la ligne D ?

4. Que révèle la ligne E ?

5. Pourquoi les adresses de la base sont-elles toujours 10.0.20.14 ?

6. La ligne C suffit-elle à dire qui a rejeté ?

\$ Prérequis : VPC_ID défini ; droits iam:CreateRole et iam:PassRole ; remplacer user7

1. Groupe de journaux, avec une rétention limitée

```
aws logs create-log-group --log-group-name /vpc/user7-flowlogs
aws logs put-retention-policy --log-group-name /vpc/user7-flowlogs --retention-in-days 7
```

2. Rôle que le service Flow Logs endosse pour écrire dans CloudWatch Logs

```
cat > fl-trust.json <<'EOF'
{"Version":"2012-10-17","Statement":[{"Effect":"Allow",
  "Principal":{"Service":"vpc-flow-logs.amazonaws.com"},"Action":["sts:AssumeRole"]}]}
EOF
cat > fl-perm.json <<'EOF'
{"Version":"2012-10-17","Statement":[{"Effect":"Allow",
  "Action":["logs:CreateLogStream","logs:PutLogEvents","logs:DescribeLogGroups","logs:DescribeLogStreams"],
  "Resource":["*"]}]}
EOF
ROLE_ARN=$(aws iam create-role --role-name user7-role-flowlogs \
  --assume-role-policy-document file://fl-trust.json --query Role.Arn --output text)
aws iam put-role-policy --role-name user7-role-flowlogs --policy-name ecriture-logs --policy-document file://fl-perm.json
```

3. Activer la capture sur tout le VPC, fenêtre d'une minute

```
aws ec2 create-flow-logs --resource-type VPC --resource-ids $VPC_ID --traffic-type ALL \
  --log-destination-type cloud-watch-logs --log-group-name /vpc/user7-flowlogs \
  --deliver-logs-permission-arn $ROLE_ARN --max-aggregation-interval 60
```

4. Suivre les enregistrements à mesure qu'ils arrivent

```
aws logs tail /vpc/user7-flowlogs --follow
```

Rôle de service. On retrouve le mécanisme du chapitre « La CLI et les rôles » : une trust policy qui désigne le service, une politique de permissions, et `iam:PassRole` pour confier le rôle. Vers S3, aucun rôle n'est nécessaire : une politique de bucket suffit.

txt Les derniers rejets vers une interface

```
fields @timestamp, srcAddr, srcPort, dstAddr, dstPort, protocol
| filter interfaceId = "eni-0a1b2c3d" and action = "REJECT"
| sort @timestamp desc
| limit 20
```

txt Un flux précis : l'application vers la base

```
fields @timestamp, srcAddr, dstAddr, dstPort, action
| filter srcAddr = "10.0.10.25" and dstAddr = "10.0.20.14"
  and dstPort = 5432
| sort @timestamp desc
```

txt Les ports les plus visés par les tentatives rejetées

```
filter action = "REJECT"
| stats count(*) as tentatives by dstPort
| sort tentatives desc
| limit 10
```

txt Qui consomme le plus de volume (par exemple à travers la NAT)

```
filter interfaceId = "eni-0nat1234"
| stats sum(bytes) as octets by srcAddr, dstAddr
| sort octets desc
| limit 10
```

Mode d'emploi

- Console CloudWatch, **Logs Insights** ; choisir le groupe de journaux et la période.
- Les champs des flow logs sont reconnus automatiquement : `srcAddr`, `dstAddr`, `srcPort`, `dstPort`, `action`, `interfaceId`, `bytes`.
- Trouver l'identifiant de l'interface : page de l'instance, onglet **Networking**.

Réflexe de dépannage. Filtrer sur l'interface de **destination** et sur le port visé : on voit aussitôt si la requête arrive, et ce qu'il en advient.

Poste	Ordre de grandeur
Livraison vers CloudWatch Logs	Environ 0,50 \$ par Go ingéré.
Livraison vers S3	Environ 0,25 \$ par Go.
Conservation	Tarif de CloudWatch Logs ou de S3.
Requêtes Logs Insights	Au volume de données parcouru.

Tarifs indicatifs de la région us-east-1, dégressifs avec le volume.

Le volume surprend. Un VPC actif produit des gigaoctets de flow logs par jour. Sans rétention ni filtre, la facture de journaux peut dépasser celle des serveurs observés.

Bonnes pratiques

- Fixer une **rétention** sur le groupe de journaux dès sa création.
- En permanence : niveau VPC, vers S3, éventuellement en REJECT seulement.
- Pour dépanner : niveau interface ou sous-réseau, vers CloudWatch Logs, fenêtre d'une minute, puis désactiver.
- Activer en production avant d'en avoir besoin : on ne peut pas consulter le trafic d'hier si rien n'était enregistré.
- Ajouter au format les champs utiles : identifiants de VPC et de sous-réseau, sens du flux.
- Étiqueter le flow log et son groupe de journaux.

Supprimer un flow log arrête la capture mais ne supprime pas les journaux déjà livrés : le groupe de journaux et le bucket restent à nettoyer.

Ce qu'il faut retenir

- Le security group filtre au niveau de l'interface : autorisations seulement, à états, sans ordre.
- La network ACL filtre au niveau du sous-réseau : autorisations et refus, sans état, par ordre de numéro.
- Sans état signifie qu'il faut autoriser le retour, donc les ports éphémères.
- Chaîner les security groups : chaque niveau n'accepte que le security group du niveau précédent.
- Endpoint passerelle pour S3 et DynamoDB : gratuit, par le routage. Endpoint d'interface pour le reste : payant, par le DNS.
- Les Flow Logs enregistrent qui parle à qui, et la décision ACCEPT ou REJECT, sans le contenu.

1. Un security group peut-il contenir une règle de refus ?

2. Que signifie « à états » ?

3. Pourquoi autoriser 1024-65535 dans une network ACL ?

4. Dans sg-db, quelle source pour le port 5432 ?

5. Quels services ont un endpoint passerelle ?

6. Comment un endpoint d'interface est-il trouvé par l'application ?

7. Requête ACCEPT, réponse REJECT dans les Flow Logs : qui bloque ?

Cliquer sur une question pour afficher la réponse.

Dépannage réseau, partie 1

La méthode de dépannage

Face à une connexion qui échoue, cinq questions, toujours dans le même ordre, plutôt que des essais au hasard.

- Lire le symptôme
- Poser le problème
- Les cinq points : route, security group, network ACL, adresse publique, DNS
- L'aller et le retour
- Le système et l'application
- Les commandes de test

Pourquoi une méthode

Une connexion traverse une demi-douzaine de composants, et chacun peut la faire échouer en silence. Sans méthode, on modifie des règles au hasard jusqu'à ce que « ça marche », en laissant derrière soi des ouvertures que personne ne refermera.

Ce qu'une méthode apporte

- **La rapidité** : on élimine les causes une à une, sans revenir en arrière.
- **La sécurité** : on corrige le composant fautif, au lieu de tout ouvrir.
- **La transmission** : un diagnostic se raconte et se vérifie.

Les réflexes à perdre

- Ouvrir le security group à `0.0.0.0/0` « pour voir ».
- Donner une adresse publique à l'instance « pour tester ».
- Redémarrer l'instance sans avoir rien observé.
- Changer plusieurs choses à la fois : on ne sait plus laquelle a agi.

Trois principes. Observer avant de modifier. Un seul changement à la fois, suivi d'un test. Annuler ce qui n'a rien corrigé.

Dans un VPC, presque toutes les pannes de connectivité viennent de la configuration : une route, une règle, une adresse. Le réseau d'AWS lui-même est rarement en cause.

Schéma : lire le symptôme



Le message d'erreur est le premier indice. Avant d'ouvrir la console, lire ce que dit la commande ou le journal de l'application : les trois cas mènent à des recherches complètement différentes, et le deuxième innocente le réseau.

Ce que chaque symptôme apprend

Symptôme	Ce qui s'est passé	Où chercher
Délai dépassé (timeout)	Le paquet a été abandonné en silence, ou sa réponse n'est pas revenue.	Route, security group, network ACL, adresse publique.
Connexion refusée (refused)	La machine a répondu qu'aucun service n'écoute sur ce port.	Le service est-il démarré ? Sur quel port, quelle adresse ?
Nom non résolu	Le DNS n'a pas su traduire le nom.	Orthographe, options DNS du VPC, zone hébergée, DNS privé d'un endpoint.
Erreur 502, 503 ou 504 d'un load balancer	Le load balancer est joint, mais pas l'application derrière lui.	Security group de l'application, contrôles de santé, application.
Erreur 403 ou AccessDenied	Le service est joint ; c'est l'autorisation qui manque.	IAM, politique de ressource, politique d'endpoint : pas le réseau.
Erreur de certificat TLS	La connexion est établie, la négociation échoue.	Nom utilisé, certificat, horloge : pas le réseau.
Lenteur, coupures intermittentes	Le chemin existe mais se dégrade.	Charge de la cible, saturation, une zone ou une cible défaillante.

Définition : délai dépassé (timeout)

Abandon d'une tentative de connexion faute de réponse dans le temps imparti. Le paquet, ou sa réponse, a été perdu ou filtré.

Pourquoi le filtrage produit un délai. Un security group ou une network ACL qui refuse ne répond rien : le paquet disparaît. Le client attend, puis abandonne. C'est voulu : un refus explicite renseignerait un attaquant.

Définition : connexion refusée (refused)

Réponse immédiate de la machine de destination indiquant qu'aucun service n'écoute sur le port demandé.

« Connexion refusée » est une bonne nouvelle pour le réseau : routes, filtrage et adresses sont corrects, puisque la machine a répondu.

Question	Exemple
Qui est la source ?	Le serveur applicatif <code>10.0.10.25</code> , sous-réseau privé a, <code>sg-app</code> .
Qui est la destination ?	La base <code>10.0.20.14</code> , sous-réseau isolé a, <code>sg-db</code> .
Quel protocole, quel port ?	TCP 5432.
Qui ouvre la connexion ?	L'application, vers la base.
Quel est le symptôme exact ?	Délai dépassé au bout de 30 secondes.
Depuis quand ?	Depuis le déploiement de ce matin.
Qu'est-ce qui fonctionne ?	L'autre serveur applicatif joint la base.

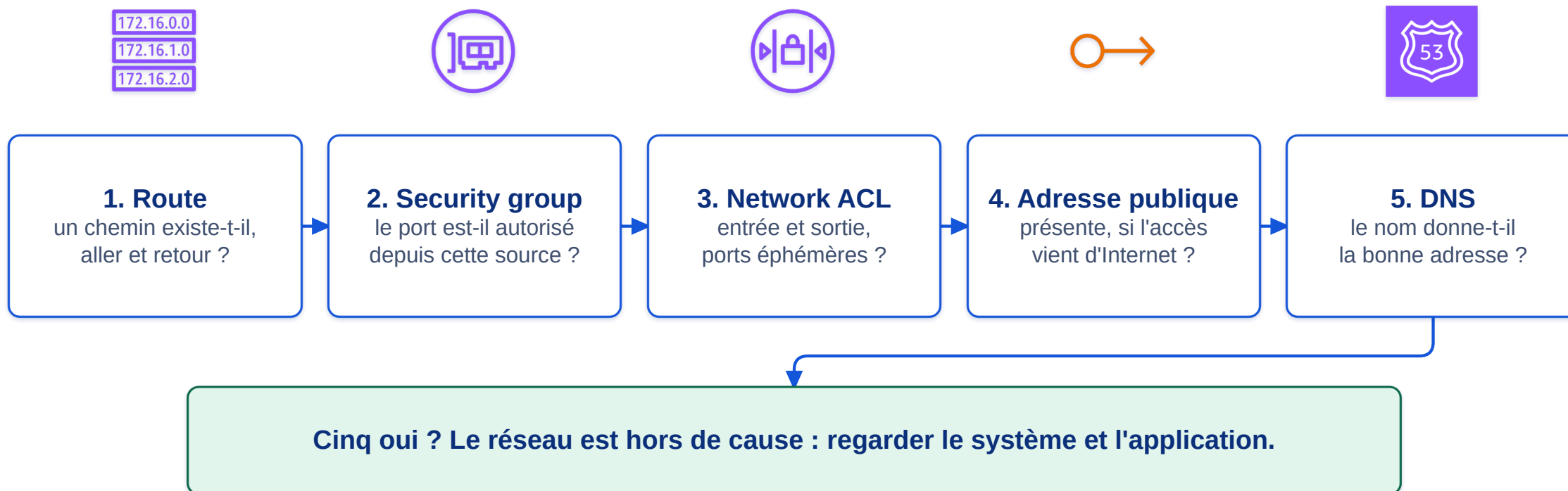
Pourquoi ces questions

- Source et destination donnent les **deux sous-réseaux** et les **deux security groups** à examiner.
- Le port donne la règle à chercher.
- Le sens dit de quel côté doit se trouver la règle entrante.
- « Depuis quand » et « ce qui fonctionne » désignent souvent le coupable avant tout examen.

Comparer. Si une ressource semblable fonctionne, chercher la différence : même sous-réseau ? mêmes security groups ? même table de routage ? La panne est dans l'écart.

Chercher le changement. CloudTrail montre qui a modifié une règle ou une route, et quand : filtrer sur les événements `AuthorizeSecurityGroupIngress`, `ReplaceRoute`, `DeleteNatGateway`.

Schéma : la méthode en cinq points



À chaque non : corriger, retester, et seulement ensuite passer au point suivant.

Pourquoi cet ordre. On commence par ce qui conditionne tout le reste : sans chemin, inutile d'examiner le filtrage. On poursuit par le security group, cause la plus fréquente, puis par la network ACL, plus rare. L'adresse publique ne concerne que les accès depuis ou vers Internet. Le DNS vient en dernier dans la liste, mais se vérifie en une commande : rien n'interdit de l'écarter d'emblée.

Questions

- Quelle table de routage s'applique au sous-réseau de la **source** ?
- Contient-elle une route qui couvre l'adresse de destination ? Vers quelle cible ?
- Cette cible existe-t-elle encore (pas de « blackhole ») ?
- Même question pour le **retour**, depuis le sous-réseau de la destination.

Situation	Route attendue
Vers une ressource du même VPC	La route locale : toujours présente.
Depuis ou vers Internet, sous-réseau public	0.0.0.0/0 vers l'Internet Gateway.
Vers Internet, sous-réseau privé	0.0.0.0/0 vers une NAT Gateway.
Vers S3 par endpoint	Liste de préfixes vers l'endpoint.

\$ Prérequis : SUBNET contient l'identifiant du sous-réseau de la source

```
# Table appliquée au sous-réseau (vide : table principale)
aws ec2 describe-route-tables \
  --filters Name=association.subnet-id,Values=$SUBNET \
  --query 'RouteTables[].RouteTableId' --output text
```

```
# Ses routes : destination, cible, état
aws ec2 describe-route-tables \
  --filters Name=association.subnet-id,Values=$SUBNET \
  --output table --query 'RouteTables[0].Routes[].[DestinationCidrBlock,GatewayId,NatGatewayId,State]'
```

```
# Routes en trou noir dans tout le VPC
aws ec2 describe-route-tables \
  --filters Name=vpc-id,Values=$VPC_ID \
    Name=route.state,Values=blackhole \
  --query 'RouteTables[].RouteTableId' --output text
```

Raccourci. À l'intérieur d'un même VPC, la route existe toujours : passer directement au point 2. Le point 1 concerne surtout les échanges avec Internet et avec d'autres réseaux.

Questions

- Quels security groups la **destination** porte-t-elle réellement ?
- L'un d'eux a-t-il une règle **entrante** sur ce port et ce protocole ?
- La source de cette règle inclut-elle l'appelant : sa plage, ou un security group dont il est membre ?
- Les règles **sortantes** de la source laissent-elles partir ce trafic ?

Les trois erreurs habituelles. La règle est sur le mauvais security group. Le port de la règle n'est pas celui sur lequel le service écoute. La source cite un security group que l'appelant ne porte pas.

\$ Prérequis : INSTANCE contient l'identifiant de l'instance de destination

```
# Security groups portés par l'instance
aws ec2 describe-instances --instance-ids $INSTANCE \
  --query 'Reservations[0].Instances[0].SecurityGroups' \
  --output table
```

```
# Règles entrantes d'un security group
aws ec2 describe-security-group-rules \
  --filters Name=group-id,Values=$SG_DB --output table \
  --query 'SecurityGroupRules[?!IsEgress].
    [IpProtocol,FromPort,ToPort,CidrIpv4,
    ReferencedGroupInfo.GroupId]'
```

```
# Pour une base RDS
aws rds describe-db-instances \
  --db-instance-identifier shop-db --query \
  'DBInstances[0].VpcSecurityGroups[].VpcSecurityGroupId'
```

Dans la console. Onglet **Security** de l'instance : toutes les règles effectives, tous security groups réunis. Pour un load balancer ou une base, les security groups figurent dans leur propre page.

Questions

- Les sous-réseaux de la source et de la destination ont-ils une network ACL personnalisée ? Si c'est celle par défaut, intacte, passer au point 4.
- Network ACL de la **destination** : règle entrante sur le port du service ? règle sortante sur les ports éphémères ?
- Network ACL de la **source** : règle sortante sur le port du service ? règle entrante sur les ports éphémères ?
- Une règle DENY de plus petit numéro passe-t-elle avant l'autorisation ?

Quatre règles pour un flux entre deux sous-réseaux filtrés : deux par network ACL. C'est ce qui rend ce point fastidieux, et ce qui explique que l'on y trouve des oublis.

\$ Prérequis : SUBNET contient l'identifiant du sous-réseau examiné

```
# Network ACL du sous-réseau : est-ce celle par défaut ?
aws ec2 describe-network-acls \
  --filters Name=association.subnet-id,Values=$SUBNET \
  --query 'NetworkAcls[0].[NetworkAclId,IsDefault]' \
  --output text

# Ses règles, triées par numéro (Egress = sortante)
aws ec2 describe-network-acls \
  --filters Name=association.subnet-id,Values=$SUBNET \
  --output table --query '
    sort_by(NetworkAcls[0].Entries,&RuleNumber)[].
    [Egress,RuleNumber,Protocol,PortRange.From,
     PortRange.To,CidrBlock,RuleAction]'
```

Lecture. Le protocole est un numéro (6 pour TCP, -1 pour tous). Le numéro de règle 32767 est la règle finale, notée * dans la console.

Indice fort. Dans les Flow Logs : requête acceptée, réponse rejetée. C'est la signature d'une network ACL.

Ce point ne concerne que les échanges avec Internet

- **Accès depuis Internet** : la ressource a-t-elle une adresse publique ou une Elastic IP ? Est-elle dans un sous-réseau public ? L'Internet Gateway est-elle attachée ?
- **Sortie vers Internet depuis un sous-réseau public** : sans adresse publique, pas de sortie.
- **Sortie depuis un sous-réseau privé** : la NAT Gateway est-elle disponible, dans un sous-réseau public, avec son Elastic IP ?
- L'adresse utilisée par le client est-elle toujours la bonne ? Une adresse automatique change à chaque arrêt de l'instance.

\$ Prérequis : INSTANCE contient l'identifiant de l'instance

```
# Adresses de l'instance, et son sous-réseau
aws ec2 describe-instances --instance-ids $INSTANCE \
  --output table --query 'Reservations[0].Instances[0].
    [PrivateIpAddress,PublicIpAddress,SubnetId] '

# État des NAT Gateway du VPC, et leur sous-réseau
aws ec2 describe-nat-gateways \
  --filter Name=vpc-id,Values=$VPC_ID --output table \
  --query 'NatGateways[][NatGatewayId,State,SubnetId,
    NatGatewayAddresses[0].PublicIp] '

# Depuis l'instance : avec quelle adresse sort-elle ?
curl -s --max-time 5 https://checkip.amazonaws.com
```

Interpréter le dernier test. L'adresse affichée est celle de l'instance (sous-réseau public) ou celle de la NAT Gateway (sous-réseau privé). Un délai dépassé : aucune sortie vers Internet.

Questions

- Le nom est-il résolu ? En quelle adresse ?
- Est-ce l'adresse attendue : privée depuis le VPC, publique depuis Internet ?
- Les options DNS du VPC sont-elles activées (**DNS resolution**, **DNS hostnames**) ?
- Pour un endpoint d'interface : le DNS privé est-il activé ?
- Pour un nom à soi : l'enregistrement existe-t-il dans la bonne zone Route 53, et pointe-t-il vers la bonne cible ?

Départager nom et réseau. Si la connexion fonctionne avec l'adresse IP mais pas avec le nom, le problème est le DNS. Si elle échoue dans les deux cas, il est ailleurs.

\$ Depuis l'instance source

```
# Le nom est-il résolu, et en quoi ?
dig +short shop-db.abc123.eu-west-3.rds.amazonaws.com
getent hosts logs.eu-west-3.amazonaws.com

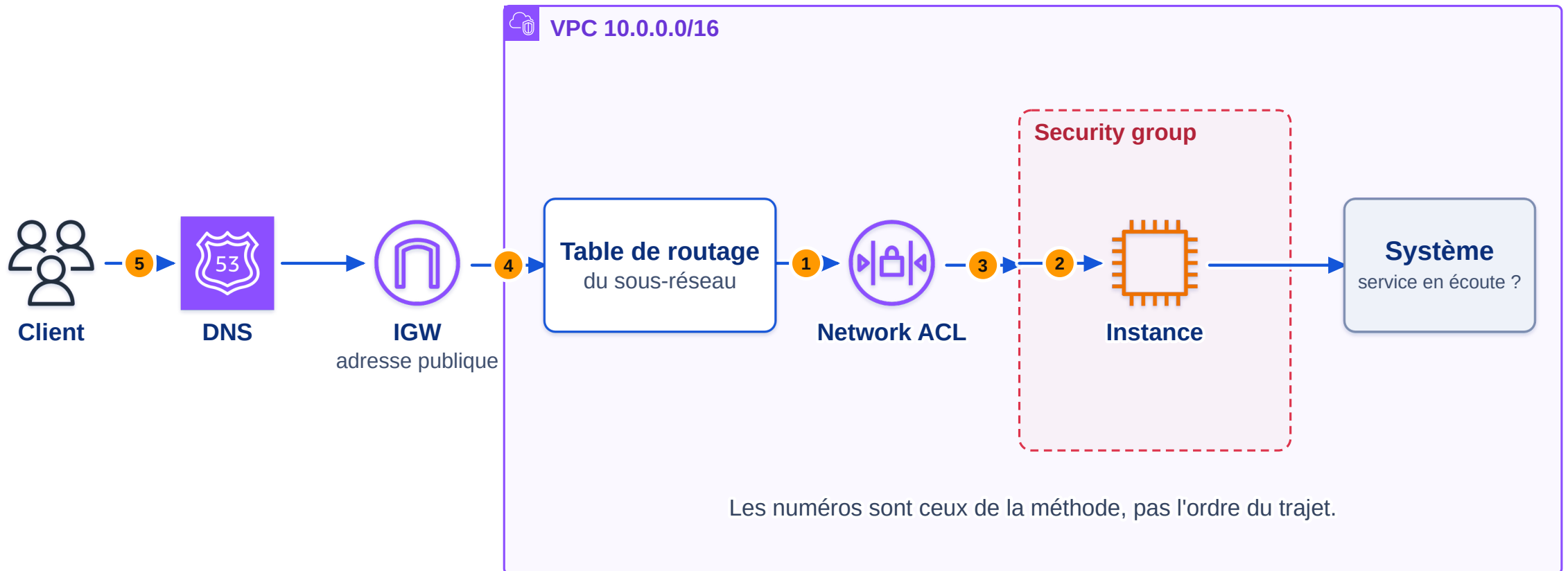
# Quel résolveur l'instance utilise-t-elle ?
cat /etc/resolv.conf      # attendu : l'adresse en .2 du VPC
```

\$ Depuis le poste d'administration : options DNS du VPC

```
aws ec2 describe-vpc-attribute --vpc-id $VPC_ID \
  --attribute enableDnsSupport \
  --query EnableDnsSupport.Value
aws ec2 describe-vpc-attribute --vpc-id $VPC_ID \
  --attribute enableDnsHostnames \
  --query EnableDnsHostnames.Value
```

Cache. Une application garde parfois en mémoire une ancienne adresse. Après la bascule d'une base ou le remplacement d'un load balancer, un redémarrage de l'application peut être nécessaire.

Schéma : les cinq points sur le trajet



Lecture. Sur le trajet d'un client d'Internet vers une instance, chaque point de la méthode correspond à un endroit précis. Le sixième composant, le système de l'instance, n'appartient plus au réseau du VPC.

Aller et retour. Le schéma montre l'aller. Le retour repasse par les mêmes composants en sens inverse : la table de routage du sous-réseau de l'instance, et les règles sortantes de sa network ACL.

Composant	À l'aller (de la source vers la destination)	Au retour (la réponse)
Table de routage	Celle du sous-réseau de la source.	Celle du sous-réseau de la destination : elle doit savoir revenir vers la source.
Security group de la source	Règle sortante.	Rien : le suivi de connexion laisse entrer la réponse.
Network ACL de la source	Règle sortante, port du service.	Règle entrante, ports éphémères.
Network ACL de la destination	Règle entrante, port du service.	Règle sortante, ports éphémères.
Security group de la destination	Règle entrante.	Rien : le suivi de connexion laisse sortir la réponse.
Internet Gateway, NAT Gateway	Traduction d'adresse.	Traduction inverse, automatique.

Où le retour se perd. Dans les deux composants sans mémoire : une table de routage qui ne connaît pas le chemin inverse (peering, VPN, route oubliée), ou une network ACL sans ports éphémères. Jamais dans un security group.

Symptôme identique. Que l'aller ou le retour soit bloqué, le client voit un délai dépassé. Seuls les Flow Logs de la destination font la différence : absents ou rejetés si l'aller échoue, acceptés puis rejetés si c'est le retour.

Vérification sur l'instance	Commande
Le service est-il démarré ?	<code>systemctl status nginx</code>
Sur quel port et quelle adresse écoute-t-il ?	<code>sudo ss -tlnp</code>
Répond-il en local ?	<code>curl -v http://localhost:8080/</code>
Un pare-feu du système bloque-t-il ?	<code>sudo nft list ruleset</code> , <code>sudo firewall-cmd --list-all</code>
Que disent ses journaux ?	<code>journalctl -u nginx -n 50</code>

Causes fréquentes côté système

- Le service écoute sur `127.0.0.1` seulement : il n'est joignable que depuis la machine elle-même. Il doit écouter sur `0.0.0.0` ou sur l'adresse privée.
- Le service écoute sur un autre port que celui de la règle.
- Le service n'a pas démarré, ou s'est arrêté.
- Un pare-feu local (firewalld, pare-feu Windows) refuse le port.
- La machine est saturée : mémoire, processeur, disque plein.

Comment accéder à une instance injoignable. Par Session Manager, qui ne dépend ni du port 22 ni d'une adresse publique. À défaut, la console série EC2 ou la capture d'écran de l'instance.

\$ Depuis la source (Linux)

```
# Le port est-il joignable ? (5 secondes au plus)
nc -zv -w 5 10.0.20.14 5432
```

```
# Sans nc : avec bash seul
timeout 5 bash -c '</dev/tcp/10.0.20.14/5432' \
  && echo ouvert || echo "ferme ou filtre"
```

```
# Requête HTTP détaillée : résolution, connexion, TLS
curl -v --max-time 5 https://shop.utopios.example/
```

```
# Résolution DNS
dig +short shop.utopios.example
```

```
# Adresse de sortie vers Internet
curl -s --max-time 5 https://checkip.amazonaws.com
```

Résultat de `nc`

Signification

succeeded, open

Chemin, filtrage et service sont corrects.

timed out

Paquet perdu : route ou filtrage.

Connection refused

Machine atteinte, service absent.

Outils trompeurs

- **ping** : échoue si ICMP n'est pas autorisé, même quand le service fonctionne. Ne prouve rien.
- **traceroute** : le routeur du VPC et les passerelles ne répondent pas comme des routeurs classiques ; le résultat est peu lisible.
- **telnet** : fonctionne, mais rarement installé ; `nc` le remplace.

Tester au plus près. Lancer le test depuis la machine qui échoue réellement, pas depuis son poste : la source fait partie du problème.

Méthode

Du symptôme à la cause : tableau de correspondance

Symptôme	Cause la plus probable	Point
Instance publique injoignable depuis Internet	Règle entrante absente, ou pas d'adresse publique.	2, 4
Instance joignable hier, plus aujourd'hui, après un arrêt	Adresse publique automatique changée.	4
Instance privée sans accès à Internet	Route vers la NAT absente ou en trou noir.	1
Application qui ne joint pas la base	Source de la règle de sg-db incorrecte.	2
Fonctionne dans un sens, pas dans l'autre	Network ACL : ports éphémères.	3
Un sous-réseau entier coupé d'un coup	Network ACL ou table de routage modifiée.	1, 3
Fonctionne par adresse IP, pas par nom	DNS.	5
Load balancer en erreur 504	sg-app n'autorise pas sg-alb, ou application arrêtée.	2
S3 inaccessible depuis un sous-réseau isolé	Endpoint absent ou non associé à la table.	1
« Connection refused »	Service arrêté ou autre port.	Système

Mode d'emploi. Ce tableau indique par où commencer, pas par où finir : on vérifie la cause probable, et si elle est écartée, on reprend la méthode dans l'ordre.

Dépannage réseau, partie 2

Les outils de diagnostic

Deux outils se complètent : Reachability Analyzer dit ce que la configuration permet, les Flow Logs disent ce qui se passe réellement.

- Panorama des outils
- Reachability Analyzer
- Lire une analyse
- Les Flow Logs en dépannage
- Comparer les deux
- Tester de l'intérieur

Outils **Panorama des outils**



Reachability Analyzer

Analyse la configuration entre une source et une destination, et désigne le composant qui bloque.



VPC Flow Logs

Montrent le trafic réel : ce qui arrive à une interface, accepté ou rejeté.



Resource map

Carte du VPC dans la console : sous-réseaux, tables de routage, passerelles et leurs liens.



Network Access Analyzer

Recherche les chemins d'accès non souhaités, par exemple d'Internet vers une base.



CloudTrail

Dit qui a modifié une règle, une route ou une passerelle, et quand.



Session Manager

Ouvre un terminal sur une instance pour tester de l'intérieur, sans port ni adresse publique.

Question	Outil
La configuration permet-elle ce flux ?	Reachability Analyzer
Le paquet arrive-t-il, et qu'en fait-on ?	VPC Flow Logs
Quel sous-réseau est public, quelle table s'applique ?	Resource map
Qu'est-ce qui a changé ?	CloudTrail
Que voit la machine elle-même ?	Session Manager

Définition : Reachability Analyzer

Outil qui examine la configuration réseau entre deux ressources d'un VPC et indique si un chemin existe. S'il n'en existe pas, il désigne le composant qui l'empêche.

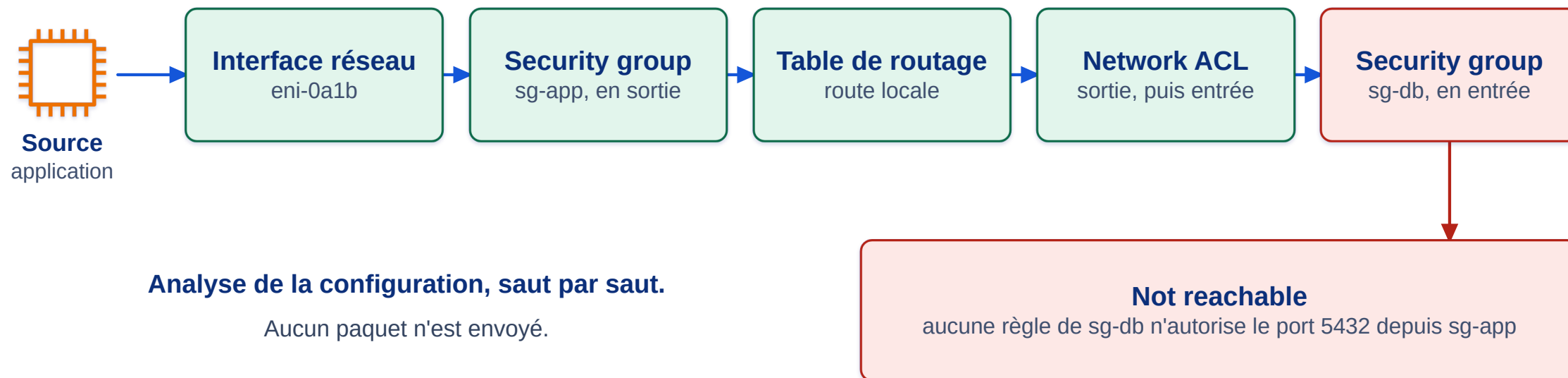
Fonctionnement

- On désigne une **source**, une **destination**, un protocole et, si l'on veut, un port.
- L'outil lit la configuration : tables de routage, security groups, network ACL, passerelles, endpoints, peerings.
- Il reconstitue le chemin saut par saut.
- Résultat : **Reachable**, avec le détail du chemin ; ou **Not reachable**, avec l'explication.

Élément	Détail
Sources et destinations	Instance, interface réseau, Internet Gateway, endpoint, passerelle VPN, Transit Gateway, adresse IP.
Trafic envoyé	Aucun : c'est une analyse de la configuration.
Durée	Quelques dizaines de secondes.
Coût	Environ 0,10 \$ par analyse.
Accès	Console VPC, rubrique Network Analysis ; ou AWS CLI.

Aucun risque. Rien n'est modifié et aucun paquet ne circule : on peut l'utiliser en production, et même vérifier un chemin avant de déployer l'application.

Schéma : une analyse saut par saut



Lecture. L'analyse suit le paquet depuis l'interface de la source. Chaque composant franchi est validé, jusqu'à celui qui refuse. L'explication nomme le composant, son identifiant, et la raison : ici, aucune règle entrante ne correspond.

Gain. Les points 1, 2 et 3 de la méthode sont vérifiés d'un coup, à l'aller, sans ouvrir une seule page de configuration. Il reste à corriger le composant désigné, puis à relancer l'analyse.

\$ Prérequis : identifiants de l'instance source (SRC) et de l'instance de destination (DST) ; pour une base RDS, utiliser l'identifiant de son interface réseau

```
# 1. Décrire le chemin à analyser : source, destination, protocole, port
NIP=$(aws ec2 create-network-insights-path --source $SRC --destination $DST \
--protocol tcp --destination-port 5432 \
--tag-specifications 'ResourceType=network-insights-path,Tags=[{Key=Name,Value=user7-app-vers-db}]' \
--query NetworkInsightsPath.NetworkInsightsPathId --output text)

# 2. Lancer l'analyse
NIA=$(aws ec2 start-network-insights-analysis --network-insights-path-id $NIP \
--query NetworkInsightsAnalysis.NetworkInsightsAnalysisId --output text)

# 3. Lire le résultat (attendre l'état "succeeded")
aws ec2 describe-network-insights-analyses --network-insights-analysis-ids $NIA \
--query 'NetworkInsightsAnalyses[0].[Status,NetworkPathFound]' --output text

# 4. En cas d'échec : le code d'explication et le composant en cause
aws ec2 describe-network-insights-analyses --network-insights-analysis-ids $NIA --output table \
--query 'NetworkInsightsAnalyses[0].Explanations[][ExplanationCode,SecurityGroup.Id,Acl.Id,RouteTable.Id]'

# 5. Après correction, relancer une analyse sur le même chemin (étape 2), puis nettoyer
aws ec2 delete-network-insights-analysis --network-insights-analysis-id $NIA
aws ec2 delete-network-insights-path --network-insights-path-id $NIP
```

Chemin et analyse. Le chemin (`nip-`) est la question, que l'on conserve ; l'analyse (`nia-`) est une réponse à un instant donné. On peut rejouer la même question après chaque modification, ou régulièrement pour détecter une régression.

Outils

Lire le résultat, et connaître les limites

Explication (exemples)	Signification
Règles de security group	Aucune règle n'autorise ce flux sur le security group indiqué.
Règles de network ACL	La network ACL indiquée refuse, à l'aller ou au retour.
Aucune route vers la destination	La table de routage indiquée ne mène pas à la cible.
Route en trou noir	La cible de la route n'existe plus.
Pas d'adresse publique	La ressource ne peut pas être jointe par l'Internet Gateway.

Dans la console, le résultat s'affiche sous forme de schéma : le chemin, composant par composant, avec en rouge celui qui bloque et un lien direct vers sa page.

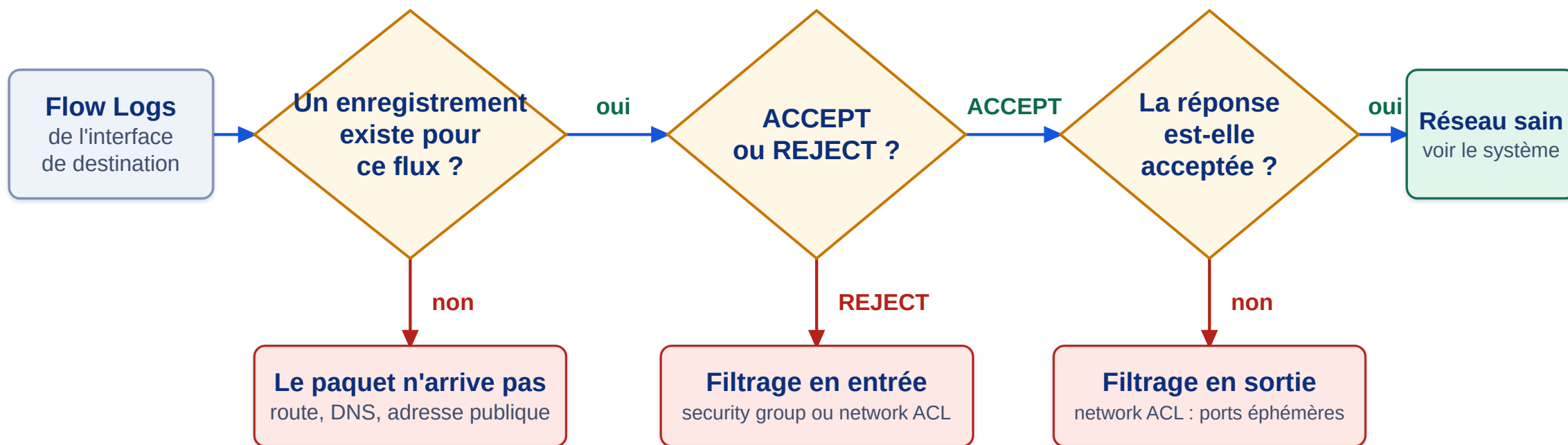
Ce que l'outil ne voit pas

- **Le système de la machine** : service arrêté, mauvais port d'écoute, pare-feu local.
- **La performance** : lenteur, pertes, saturation.
- **Ce qui est hors d'AWS** : le pare-feu de l'entreprise, le fournisseur d'accès du client.
- **Le DNS** : il travaille sur des ressources et des adresses, pas sur des noms.

« **Reachable** » ne veut pas dire « ça marche ». Cela veut dire que le réseau du VPC le permet. Si la connexion échoue quand même, la cause est dans le système, l'application ou le DNS.

Un sens à la fois. Une analyse couvre le flux de la source vers la destination, retour compris. Pour un flux ouvert dans l'autre sens, créer un second chemin.

Schéma : interpréter les Flow Logs



Démarche. Lancer le test depuis la source, attendre la livraison des journaux, puis chercher le flux sur l'interface de la **destination**, en filtrant sur l'adresse de la source et le port visé.

L'absence est une information. Aucun enregistrement signifie que le paquet n'a jamais atteint l'interface : mauvaise adresse, route manquante, ou blocage en amont, par exemple par le security group de la source en sortie.

Outils

Reachability Analyzer et Flow Logs

	Reachability Analyzer	VPC Flow Logs
Ce qu'il examine	La configuration.	Le trafic réel.
Répond à	« Ce flux est-il permis ? »	« Que s'est-il passé ? »
Besoin de trafic	Non.	Oui : il faut que la connexion soit tentée.
Préparation	Aucune.	Doit avoir été activé avant.
Délai	Quelques dizaines de secondes.	Quelques minutes.
Désigne le coupable	Oui, précisément.	Non : accepté ou rejeté, sans dire par qui.
Voit les flux inattendus	Non.	Oui : balayages, destinations inconnues.
Coût	À l'analyse.	Au volume de journaux.

Enchaînement recommandé. D'abord Reachability Analyzer : il vérifie route, security groups et network ACL en une fois. S'il conclut « Reachable » alors que la connexion échoue, passer aux Flow Logs pour voir si le paquet arrive, puis au système.

Complémentarité. L'un dit ce qui devrait se passer, l'autre ce qui se passe. Quand les deux ne concordent pas, c'est que l'hypothèse de départ est fausse : mauvaise source, mauvaise destination, mauvais port.

Tester de l'intérieur avec Session Manager

\$ Prérequis : plugin Session Manager installé sur le poste, instance gérée par Systems Manager

```
# Les instances que Systems Manager voit
aws ssm describe-instance-information --output table \
  --query 'InstanceInformationList[][InstanceId,PingStatus,PlatformName]'

# Ouvrir un terminal sur l'instance source
aws ssm start-session --target i-0abc123def4567890

# Puis, dans la session : tester le flux réel
nc -zv -w 5 10.0.20.14 5432
dig +short shop-db.abc123.eu-west-3.rds.amazonaws.com
curl -s --max-time 5 https://checkip.amazonaws.com
```

Depuis la console. Page de l'instance, bouton **Connect**, onglet **Session Manager**. Aucun outil à installer sur le poste.

Pourquoi tester depuis la source

- C'est le seul endroit d'où l'on voit le flux tel que l'application le vit : même sous-réseau, même security group, même DNS.
- Un test depuis son poste emprunte un autre chemin et ne prouve rien.

Si l'instance n'apparaît pas dans Systems Manager

- Le rôle de l'instance ne porte pas `AmazonSSMManagedInstanceCore`.
- L'agent ne peut pas joindre le service : ni NAT Gateway, ni endpoints.
- L'agent n'est pas installé ou pas démarré.

C'est en soi un diagnostic réseau : l'instance n'a pas de sortie.

Resource map

- Console VPC, page du VPC, onglet **Resource map**.
- Quatre colonnes reliées : VPC, sous-réseaux par zone, tables de routage, connexions réseau (Internet Gateway, NAT Gateway, endpoints).
- Survoler un sous-réseau met en évidence sa table et ses sorties.

En un regard : quels sous-réseaux sont publics, lesquels partagent une table, lequel n'a aucune sortie, quelle table n'est associée à rien.

Premier geste face à un VPC inconnu. Ouvrir la carte avant toute commande : la moitié des erreurs de routage s'y voient immédiatement.

\$ CloudTrail : qui a modifié les security groups ces dernières 24 heures ?

```
aws cloudtrail lookup-events --max-results 20 \
  --lookup-attributes \
    AttributeKey=EventName,AttributeValue=AuthorizeSecurityGroupIngress \
  --query 'Events[].[EventTime,Username,EventName]' \
  --output table
```

Événement à rechercher	Ce qui a changé
AuthorizeSecurityGroupIngress, RevokeSecurityGroupIngress	Règle de security group.
CreateRoute, ReplaceRoute, DeleteRoute	Route.
CreateNetworkAclEntry, ReplaceNetworkAclAssociation	Network ACL.
DeleteNatGateway, DetachInternetGateway	Passerelle.

« Ça marchait hier » : la réponse est presque toujours dans cette liste.

Dépannage réseau, partie 3

Cas pratiques

Six pannes que l'on rencontre dans tout VPC, déroulées du symptôme à la correction avec la méthode.

- Instance publique injoignable
- Instance privée sans Internet
- L'application ne joint pas la base
- L'aller passe, pas le retour
- S3 inaccessible depuis un sous-réseau isolé
- Un nom qui ne se résout pas

Cas 1 : une instance publique injoignable

Symptôme	<code>curl http://13.36.10.20/</code> depuis son poste : délai dépassé.
Contexte	Serveur web de test lancé dans <code>subnet-public-a</code> , avec le security group <code>sg-web</code> .
Ce qui fonctionne	Depuis Session Manager, <code>curl http://localhost/</code> répond.

Ce que le symptôme dit

Délai dépassé : le paquet se perd. Le service fonctionne en local : le système est hors de cause. C'est bien le réseau.

#	Vérification	Constat
1	Route du sous-réseau	<code>0.0.0.0/0</code> vers l'Internet Gateway : correct.
2	Règles entrantes de sg-web	Port 443 depuis 0.0.0.0/0. Rien sur le port 80.
3	Network ACL	Par défaut : non concernée.
4	Adresse publique	Présente : 13.36.10.20.

Cause. Le test porte sur le port 80 (`http://`), la règle n'ouvre que le 443.

Correction. Ajouter le port 80 à `sg-web` , ou tester en `https://` . Ne pas ouvrir « All traffic ».

Variantes du même cas. Pas d'adresse publique (point 4) ; instance placée par erreur dans un sous-réseau privé (point 1) ; règle ajoutée à un security group que l'instance ne porte pas (point 2).

Cas 2 : une instance privée sans accès à Internet



#	Vérification	Constat
1	Route du sous-réseau privé	La route par défaut est à l'état blackhole .
—	NAT Gateway	Introuvable : supprimée pour réduire les coûts.

Cause. La NAT Gateway a été supprimée sans retirer ni remplacer la route qui y menait.

Correction. Recréer une NAT Gateway dans un sous-réseau public, puis remplacer la route : `aws ec2 replace-route --route-table-id ... --destination-cidr-block 0.0.0.0/0 --nat-gateway-id ...`

Variantes. Sous-réseau privé non associé à la table privée ; NAT Gateway créée dans un sous-réseau privé ; table publique sans route vers l'Internet Gateway ; règle sortante du security group resserrée sans le port 443.

Cas 3 : l'application ne joint pas la base

Symptôme	Journal de l'application : « connection to 10.0.20.14 port 5432 timed out ».
Contexte	Nouveau serveur applicatif, lancé ce matin par un collègue.
Ce qui fonctionne	L'ancien serveur applicatif joint la base sans problème.

Raisonnement

Même VPC : la route locale existe, le point 1 est acquis. Un serveur fonctionne et l'autre non : chercher ce qui les distingue. Reachability Analyzer, lancé du nouveau serveur vers la base sur le port 5432, répond « Not reachable » et désigne `sg-db`.

Élément	Ancien serveur	Nouveau serveur
Sous-réseau	privé a	privé b
Security group	sg-app	default

Cause. Le nouveau serveur a été lancé sans préciser de security group : il a reçu celui par défaut. `sg-db` n'accepte que `sg-app`.

Correction. Remplacer le security group de l'instance par `sg-app`. Aucune règle à modifier : le filtrage faisait exactement ce pour quoi il a été écrit.

Mauvaise correction. Ajouter à `sg-db` une règle pour la plage `10.0.11.0/24` : cela « marche », mais ouvre la base à tout le sous-réseau.

Cas 4 : l'aller passe, pas le retour

Symptôme	Depuis hier, plus aucun client ne joint le site : délai dépassé.
Contexte	Une network ACL personnalisée a été associée aux sous-réseaux publics « pour renforcer la sécurité ».
Indice	Le security group du load balancer n'a pas changé.

txt Flow Logs de l'interface du load balancer

```
203.0.113.12 10.0.0.31 51234 443 6 3 180 ... ACCEPT OK
10.0.0.31 203.0.113.12 443 51234 6 3 180 ... REJECT OK
```

#	Vérification	Constat
1	Route	Inchangée, correcte.
2	Security group	443 depuis 0.0.0.0/0 : correct.
3	Network ACL, entrée	Règle 100 : 443 autorisé.
3	Network ACL, sortie	Seul le port 443 est autorisé.

Cause. La réponse repart vers le port éphémère du client (51234), que la network ACL n'autorise pas en sortie.

Correction. Règle sortante TCP 1024-65535 vers 0.0.0.0/0. Et règle entrante sur la même plage, pour les réponses aux connexions ouvertes par le load balancer et la NAT Gateway.

Cas 5 : S3 inaccessible depuis un sous-réseau isolé

Symptôme

`aws s3 ls s3://shop-exports` depuis une instance isolée : la commande reste bloquée, puis échoue sur un délai de connexion.

Contexte

Un endpoint passerelle S3 a pourtant été créé la semaine dernière.

Ce qui fonctionne

La même commande, depuis une instance d'un sous-réseau privé.

Raisonnement

Délai dépassé : pas un problème de droits (ce serait `AccessDenied`). L'instance privée y parvient, par sa NAT ou par l'endpoint. Point 1 : quelle route mène à S3 depuis le sous-réseau isolé ?

\$ Tables de routage associées à l'endpoint

```
aws ec2 describe-vpc-endpoints \
  --filters Name=vpc-id,Values=$VPC_ID \
  --query 'VpcEndpoints[][ServiceName,RouteTableIds]'
# com.amazonaws.eu-west-3.s3 [ rtb-prive-a, rtb-prive-b ]
```

Cause. L'endpoint n'est associé qu'aux tables privées. La table du sous-réseau isolé ne contient que la route locale : aucun chemin vers S3.

Correction. Ajouter la table isolée à l'endpoint : `aws ec2 modify-vpc-endpoint --vpc-endpoint-id ... --add-route-table-ids ...`

Si l'erreur avait été `AccessDenied` : regarder la politique d'endpoint et la politique du bucket, pas le réseau.

Cas 6 : un nom qui ne se résout pas comme prévu

Symptôme

L'agent CloudWatch d'une instance isolée n'envoie aucun journal : délai dépassé vers `logs.eu-west-3.amazonaws.com`.

Contexte

Un endpoint d'interface `logs` existe dans le sous-réseau, avec un security group ouvert sur 443.

\$ Depuis l'instance

```
dig +short logs.eu-west-3.amazonaws.com
# 52.95.151.34 (adresse publique)

nc -zv -w 5 10.0.20.87 443
# Connection to 10.0.20.87 443 port succeeded
```

Raisonnement

L'adresse privée de l'endpoint répond : route et filtrage sont bons. Mais le nom du service donne une adresse **publique**, injoignable depuis un sous-réseau isolé. C'est le point 5 : le DNS.

Cause. L'endpoint a été créé sans DNS privé, ou l'option **DNS hostnames** du VPC est désactivée : le nom standard continue de pointer vers Internet.

Correction. Activer DNS hostnames sur le VPC, puis le DNS privé sur l'endpoint : `aws ec2 modify-vpc-endpoint --vpc-endpoint-id ... --private-dns-enabled`

Leçon. Tester l'adresse, puis le nom. Quand l'adresse répond et que le nom échoue, il n'y a plus rien à chercher dans les routes ni les règles.

#	Étape
0	Lire le message. Délai dépassé : réseau. Refusée : système. Nom non résolu : DNS. AccessDenied : droits.
0	Poser le problème. Source, destination, port, sens, depuis quand, ce qui fonctionne.
1	Route. Table du sous-réseau source, route vers la destination, cible vivante, retour.
2	Security group. Règle entrante de la destination : port, source. Règle sortante de la source.
3	Network ACL. Si personnalisée : entrée et sortie des deux sous-réseaux, ports éphémères, ordre.
4	Adresse publique. Pour Internet seulement : adresse, sous-réseau public, Internet Gateway, NAT.
5	DNS. Le nom donne-t-il la bonne adresse ? Options DNS du VPC, DNS privé.
6	Système. Service démarré, port et adresse d'écoute, pare-feu local.

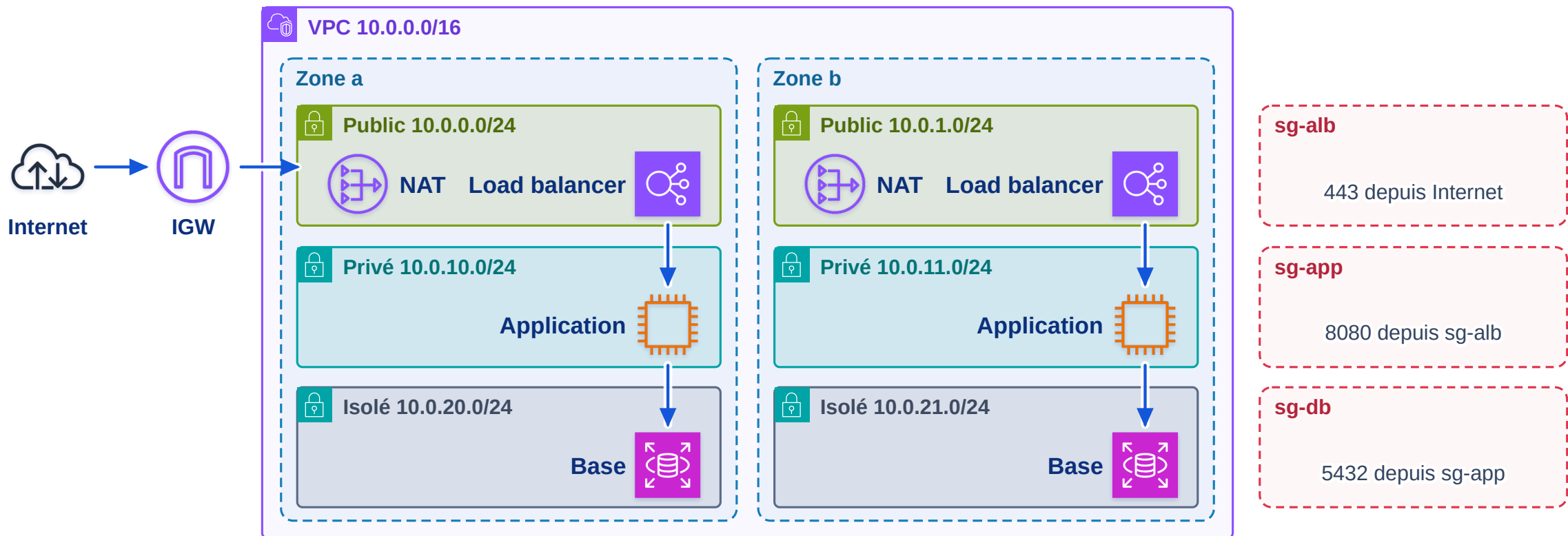
Outils, dans l'ordre

1. `nc -zv` ou `curl -v` depuis la source : confirmer le symptôme.
2. Reachability Analyzer : points 1 à 3 en une analyse.
3. Flow Logs sur l'interface de destination : le paquet arrive-t-il ?
4. `dig` : le nom.
5. Session Manager sur la destination : `ss -tlnp`.
6. CloudTrail : qu'est-ce qui a changé ?

Règles de conduite. Observer avant de modifier. Un changement à la fois. Corriger le composant fautif, sans élargir les autres. Annuler ce qui n'a rien résolu. Noter la cause.

Interdits. `0.0.0.0/0` « pour tester », adresse publique « provisoire », suppression d'une network ACL « pour voir ».

Schéma : le VPC de UtopiosShop, filtrage compris



Trois security groups chaînés

Chaque niveau n'accepte que le précédent : Internet vers le load balancer, le load balancer vers l'application, l'application vers la base.

Accès privés

Un endpoint passerelle S3 (non représenté), associé aux tables privées et isolées : le trafic vers S3 ne passe ni par la NAT ni par Internet.

Visibilité

Flow Logs activés sur le VPC ; network ACL par défaut conservées ; administration par Session Manager, sans port ouvert.

Ce qu'il faut retenir

- Le symptôme oriente : délai dépassé pour le réseau, connexion refusée pour le système, nom non résolu pour le DNS.
- Poser le problème : source, destination, port, sens.
- Cinq points, dans l'ordre : route, security group, network ACL, adresse publique, DNS. Puis le système.
- Toujours penser à l'aller et au retour.
- Reachability Analyzer analyse la configuration et désigne le composant qui bloque, sans envoyer de paquet.
- Les Flow Logs montrent le trafic réel : accepté, rejeté, ou absent.
- On corrige le composant fautif ; on n'ouvre pas tout.

1. Que signifie « Connection refused » pour le réseau ?

2. Pourquoi un filtrage produit-il un délai dépassé ?

3. Quels sont les cinq points de la méthode ?

4. Reachability Analyzer envoie-t-il du trafic ?

5. Il répond « Reachable » mais la connexion échoue. Où chercher ?

6. Aucun enregistrement dans les Flow Logs de la destination : conclusion ?

7. Pourquoi ne pas se fier au ping ?

Cliquer sur une question pour afficher la réponse.

#	Pratique	Chapitre
1	Un plan d'adressage sans chevauchement, avec de la place libre.	VPC et sous-réseaux
2	Au moins deux zones, structure identique dans chacune.	VPC et sous-réseaux
3	Trois niveaux : public, privé, isolé. Le VPC par défaut reste inutilisé.	VPC et sous-réseaux
4	Tables de routage personnalisées, associations explicites, table principale sans sortie.	Routage et accès à Internet
5	Le moins d'adresses publiques possible ; des noms DNS dans les configurations.	Routage et accès à Internet
6	Un security group par rôle, chaînés entre eux ; aucun port d'administration ouvert.	Filtrage et accès privés
7	Network ACL par défaut, sauf besoin précis de refus ou de conformité.	Filtrage et accès privés
8	Endpoints passerelle pour S3 et DynamoDB ; endpoints d'interface quand ils se justifient.	Filtrage et accès privés
9	Flow Logs activés avant d'en avoir besoin, avec une rétention définie.	Filtrage et accès privés
10	Une méthode de diagnostic, et jamais d'ouverture « pour tester ».	Dépannage réseau
11	Le réseau décrit en code, relu et versionné.	Tout ce support

Fil conducteur. Chaque ressource n'est joignable que par ceux qui en ont besoin, sur le seul port nécessaire, par le chemin le plus court ; et l'on garde la trace de ce qui circule.

Terme	Définition
Security group	Règles d'autorisation attachées à une interface réseau ; filtrage à états.
Network ACL	Règles numérotées d'autorisation et de refus associées à un sous-réseau ; filtrage sans état.
À états (stateful)	La réponse à une connexion autorisée passe automatiquement.
Sans état (stateless)	Chaque sens est filtré séparément.
Règle entrante, sortante	Règle qui s'applique aux connexions reçues, ou ouvertes, par la ressource.
Port éphémère	Port source temporaire d'un client, vers lequel repart la réponse.
Security group par défaut	Security group du VPC qui autorise tout trafic entre ses membres.
Référence à un security group	Règle dont la source est un autre security group.
Chaînage	Suite de security groups dont chacun n'accepte que le précédent.
Liste de préfixes	Ensemble nommé de plages CIDR, utilisable dans une règle ou une route.
Session Manager	Accès terminal à une instance sans port entrant ni clé SSH.
Défense en profondeur	Empilement de protections indépendantes.

Terme	Définition
VPC endpoint	Accès privé à un service AWS depuis un VPC, sans Internet.
Endpoint passerelle	Endpoint sous forme de cible de routage ; S3 et DynamoDB ; gratuit.
Endpoint d'interface	Endpoint sous forme d'interface réseau privée ; la plupart des services ; payant.
AWS PrivateLink	Technologie des endpoints d'interface.
DNS privé	Résolution du nom public d'un service vers l'adresse privée de son endpoint.
Politique d'endpoint	Politique qui restreint ce qui est accessible à travers un endpoint.
VPC Flow Logs	Journal des métadonnées du trafic des interfaces réseau.
Flux	Paquets de mêmes adresses, ports et protocole, sur une fenêtre de capture.
ACCEPT, REJECT	Décision du filtrage enregistrée pour un flux.
Délai dépassé (timeout)	Absence de réponse : paquet perdu ou filtré.
Connexion refusée	Machine atteinte, aucun service sur le port.
Reachability Analyzer	Analyse de la configuration entre deux ressources, saut par saut.
Blackhole	Route dont la cible n'existe plus.

Sujet	Documentation officielle
Security groups	Control traffic using security groups
Network ACL	Control subnet traffic with network ACLs
VPC endpoints	AWS PrivateLink Guide
Flow Logs	Logging IP traffic using VPC Flow Logs
Reachability Analyzer	Reachability Analyzer Guide
Session Manager	AWS Systems Manager Session Manager
Tarifs	aws.amazon.com/vpc/pricing

Icônes. Les icônes des schémas proviennent du jeu officiel « AWS Architecture Icons », publié par AWS pour la réalisation de schémas d'architecture.

Ce qui est acquis

- Un VPC à trois niveaux sur deux zones, avec ses routes.
- Un filtrage chaîné, des accès privés, des journaux de trafic.
- Une méthode pour diagnostiquer une panne de connectivité.

Suite du parcours : le calcul

- Des instances EC2 dans les sous-réseaux privés, avec leur rôle et leur security group.
- Un load balancer dans les sous-réseaux publics.
- Un Auto Scaling group réparti sur les deux zones.

Le réseau construit ici sert de socle à toute la suite de la formation.

Avant de quitter. Endpoints d'interface, NAT Gateway, Elastic IP et Flow Logs coûtent tant qu'ils existent : supprimer ce qui ne sert plus.